



File No.: EXP202400072

RESOLUTION OF TERMINATION OF THE PROCEDURE DUE TO VOLUNTARY PAYMENT

From the procedure initiated by the Spanish Agency for Data Protection and based on the following

BACKGROUND

FIRST: On January 23, 2024, the Director of the Spanish Agency for Data Protection agreed to initiate sanctioning proceedings against BANCO COOPERATIVO ESPAÑOL, S.A. (hereinafter referred to as the claimed party). After notifying the initiation agreement and analyzing the allegations presented, on December 5, 2024, the proposed resolution was issued, which is transcribed below:

<<

File No.: EXP202400072

PROPOSED RESOLUTION OF SANCTIONING PROCEDURE

From the procedure initiated by the Spanish Agency for Data Protection and based on the following:

BACKGROUND

FIRST:

On December 13, 2022, a personal data breach was notified by the entity belonging to the GRUPO CAJA RURAL: BANCO COOPERATIVO ESPAÑOL, S.A. with NIF A79496055 (hereinafter, BCE or the entity) as the data controller. It should be noted that, as a result of notifications to the Division of Technological Innovation of this Agency regarding the personal data breach in various Entities of the aforementioned Group, including the claimed party, related to a cyber-incident, the General Subdirectorate of Data Inspection was ordered to carry out the necessary preliminary investigations to determine a possible violation of data protection regulations.

1. Initially, the notifications of the breach were made by the data processor RURAL SERVICIOS INFORMÁTICOS S.L. (hereinafter RSI), concerning 19 entities of the Group:

2. The initial notification date and additional notification date are recorded as: 12/12/2022 and 10/01/2023.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

3. However, on December 13, 2022, December 14, 2022, and December 15, 2022, notifications of the breach were made by another 7 entities of the group, including the claimed party in its capacity as data controllers, despite the fact that the data processor is the same.

The breach notification forms are accompanied by the Security Incident Report prepared in all cases by RSI, the data processor.

- Date of breach detection: 09/12/2022
- Date of breach occurrence: 10/11/2022
- Summary of the notification:

(...)

- Type of affected data:

(...)

- Total number of clients, as natural persons, who could have potentially been affected by the breach:

(...)

- Number of natural persons whose data has been effectively affected by the breach: (...)

- Number of affected individuals informed: the breach has been communicated to the affected individuals.

SECOND:

As a consequence of the notifications to the Division of Technological Innovation of this Agency regarding the personal data breach in various Entities of the GRUPO CAJA RURAL related to a

cyber-incident, an internal note from the Director of the AEPD ordered the General Subdirectorate of Data Inspection to carry out the necessary preliminary investigations to determine a possible violation of data protection regulations.

During the current proceedings, the following entities have been investigated:

(...)

In order to investigate the occurrence of the described events, on March 29, 2023, a request for information was made to RSI. The response to the request was received on April 14, 2023.

On May 12, 2023, and September 27, 2023, RSI was requested to provide additional information, and on May 26, 2023, and October 11, 2023, responses were received in the electronic headquarters of the AEPD.

In order to introduce the applications involved in the breach that will be referenced throughout this report, the description provided in the documentation submitted by RSI in the context of the investigation proceedings is reproduced below:

(...)

Additionally, RSI, in its submission dated April 14, 2023, states:

(...)

Regarding the number of users served by Electronic Banking and the modes of access:

(...)

With respect to the chronology of the events. Actions taken to minimize adverse effects and measures adopted for final resolution

In the Security Incident Analysis Report accompanying the breach notification form, it is stated:

(...)

From the areas of RSI responsible for fraud and the development of the NBE, an investigation was initiated to understand how the fraud occurred.

(...)

1. The mitigating measures taken on December 7 and 9 were:

(...)

Regarding the causes that made the breach possible

- Factors that contributed to the occurrence of the incident

(...)

Regarding the affected data

The information that may have been accessed during the breach includes personal, contact, and financial data:

"[...]

(...)

In the Security Incident Analysis Report accompanying the breach notification form, the type of information that has been extracted is analyzed by the

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

4/59

cybercriminal and the impact on individual clients, taking into account, among others, the following variables:

(...)

During the course of the investigation, RSI is requested to provide additional information regarding the data of clients who do not have an Electronic Banking Agreement to which the users involved in the breach may have had access. In its response, RSI states that:

(...)

Regarding the data processing agreement

RSI provides the Record of Processing Activities of RSI and indicates that the processing in which the Electronic Banking operations are included is the Client Management processing, where RSI acts as the processor.

RSI provides the Agreement modifying the data protection clause of the service provision contracts signed between CAJA RURAL DE JAÉN, BARCELONA Y MADRID, S.C.C. (data controller), and RSI (data processor).

RSI notes that this Agreement was signed with the Entities in 2018 and that it is the same model for all of them.

The Agreement includes, among other aspects:

- The purpose of the Agreement is to establish the legal regime applicable to the processing of personal data that is processed or may be processed by the data processor, under the service provision contracts signed between the parties, and which are under the ownership and control of the data controller.
- The data processor is obliged to process the data in accordance with the instructions of the data controller.
- The data processor will apply technical and organizational security measures to ensure an adequate level of security.
- The data processor is authorized to subcontract the companies reflected in Annex A of the Agreement – Subcontracting. The subcontractor, who also has the status of data processor, is likewise obliged to comply with the obligations established in the Agreement for the data processor and the instructions issued by the data controller.

Regarding security measures

RSI indicates that the planning for the development of the NBE extends from 2019 to 2022 and that during December 2019, a risk analysis of the NBE was conducted for both the Web version and the App. The following areas were analyzed:

(...)

From the Client Management processing, RSI indicates that a data protection risk analysis has been conducted by the Data Protection Officer. This analysis is performed with an initial review of the list of threats and the assessment of whether they apply to the processing, provides the threat assessment questionnaire, and a second part, where the risk analysis is conducted according to RSI's risk analysis methodology. The result of this analysis is provided.

RSI indicates that, (...) and that in compliance with this line of work, three security evaluations have been conducted on Ruralvía Clásica, the reports of which are provided:

- Report prepared by the company ***EMPRESA.1, on web application audit, dated 28/02/2022.
- Report prepared by the company ***EMPRESA.1, on web application audit, dated 28/04/2022.
- Report prepared by the company ***EMPRESA.2, continuous evaluation reflecting the tests conducted between 01/10/2021 and 30/04/2023, where all critical vulnerabilities are closed.

The report prepared by the Cybersecurity department of RSI is also provided, which lists the three security evaluations conducted by a third party and the status of resolution of the detected vulnerabilities.

Additionally, RSI certifies that, (...) an ethical hacking audit was conducted in June 2022 by an external provider. The audit report is attached, and it states:

(...)

RSI, in its submission dated 11/10/2023 to the AEPD, explains:

(...)

Furthermore, the audits that have been conducted subsequent to those mentioned in the previous information requests in compliance with the fraud plan are listed:

(...)

Similarly, the latest audit of compliance with security measures (...) to comply with the Delegated Regulation (...) covering the audited period from 15/12/2021 to 15/12/2022 is provided. The Report is dated 15/12/2022. Specifically, it focused on reviewing the information associated with security measures related to enhanced authentication measures across the various channels and payment services offered by RSI. The Audit Report conducted by the firm ***EMPRESA.3 is provided.

To address the detected vulnerabilities in accordance with the compliance level with ***NORMA.1, an action plan is being implemented by RSI. The current status of the Action Plan is provided.

(...)

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
6/59

Reason why the security measures implemented did not prevent the incident.

(...)

Technical and organizational measures adopted to avoid, as much as possible, incidents like the one that occurred.

In addition to the measures described above, RSI conveys in its document Response to AEPD Claim:

(...)

RSI, in its document dated upon entry to the AEPD on 11/10/2023, details the operation of these controls:

(...)

Throughout the month of February 2023, the following actions were carried out:

(...)

Information on the recurrence of these events and the number of analogous events that have occurred over time.

RSI states that these events are not recurrent, being this the first occasion on which they have occurred.

It also notes that they have not received any news from their service (...) regarding the publication of data on the dark web.

THIRD:

On January 23, 2024, the Director of the Spanish Agency for Data Protection agreed to initiate sanctioning proceedings against BCE for the alleged infringement of Article 5.1.f) of the GDPR, with an initial sanction of €15,000, granting a period of ten days to submit allegations.

This initiation agreement, which was notified to BCE in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (LPACAP), was received on January 25, 2024, as stated in the acknowledgment of receipt in the file.

FOURTH:

On January 31, 2024, BCE submitted a document requesting an extension of the deadline to present allegations and to be provided with a copy of the file.

FIFTH:

On February 5, 2024, the instructing body of the procedure agreed to extend the requested deadline by a maximum of 10 days, starting from the day after the receipt of the copy of the file, and that a copy of the file be sent to BCE.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

7/59

The aforementioned agreement was notified to BCE on February 5, 2024, as stated in the acknowledgment of receipt in the file.

SIXTH:

On February 22, 2024, the instructor of the file sent the data controller a document indicating that "Since a large part of the documentation in the file has been provided by RSI through the General Electronic Registry, the registration numbers of the submitted documents were grouped by dates, so that within 10 working days, it could communicate whether there were documents, or parts of documents, that it considered should not be provided to the defendant party, due to reasons related to commercial secrecy, personal data protection, or others."

SEVENTH:

On February 22, 2024, the data controller stated that "regarding its transfer to the defendant party, my

client considers that it is not for them to assess the legality of such transfer and/or, if applicable, the existence of any impediments or limitations that the applicable regulations may establish."

EIGHTH:

On April 16, 2024, the instructor of the procedure sent the defendant party two documents: one, transferring a copy of the administrative file in accordance with the provisions of Article 53.1 a) of the LPCAP and, independently, a second one providing the key and hash that will allow access to the documentation included in the physical medium.

NINTH:

On April 30, 2024, BCE submitted a document of allegations summarizing the following:

1. That all procedures (26) opened against the entities belonging to the Caja Rural Group be accumulated due to the intimate connection and substantial identity; the absence of culpability of the defendant party in the present case;
2. The impact on the principles of sanctioning law as a consequence of the interpretation made by the AEPD;
3. Non-existence of a violation of Article 32.1 of the GDPR;
4. Non-existence of a violation of Article 5.1.f) of the GDPR;
5. Non-existence of a violation of Article 33 of the GDPR;
6. Violation of the principle of proportionality in determining the sanctions;
7. That the proceedings be archived or a warning sanction or a significant reduction of the sanction be agreed upon.

TENTH:

On October 21, 2024, it was agreed to open a period for the practice of evidence, agreeing on the following:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

8/59

- To consider reproduced for evidentiary purposes the claim filed by the claimant and its documentation, the documents obtained and generated by the Inspection Services that are part of the file.
- To consider reproduced for evidentiary purposes the allegations to the initiation agreement presented by the respondent and the accompanying documentation.
- To request the respondent party to provide documentation proving that, if applicable, they had instructed or given orders to their data processor for the notification to the AEPD of the personal data breach subject to this sanctioning file, as well as the accreditation of both the aforementioned order and the terms contained therein, including the date of the same.

On 5/11/2024, the respondent party responded to the evidence presented, the content of which is included in the file.

ELEVENTH

:

A list of documents in the procedure is attached as an annex.

From the actions carried out in this procedure, the following have been accredited,

PROVEN FACTS

FIRST:

As stated in the public deed of elevation of social agreements granted by the entity Banco Cooperativo Español S.A, protocol number (...). Likewise, as provided in its Statutes, it has its own legal personality and full capacity to act.

The Statutes of BCE are also published on its website

<https://www.bancocooperativo.es/es/particulares/sobre-entidad>

SECOND:

On 30/4/2024, BCE submitted, along with the written allegations to the initiation agreement, the

"Agreement to modify the data protection clause of the service provision contracts signed between BCE and Rural Servicios Informáticos, S.L." dated 13/9/2018 and signed on behalf of BCE by A.A.A. and B.B.B., (...).

In this Agreement, it is specified:

"ON THE ONE HAND, BANCO COOPERATIVO ESPAÑOL, S.A. (hereinafter, Data Controller), (...)
AND

ON THE OTHER HAND, RURAL SERVICIOS INFORMATICOS, S.L. (hereinafter, Data Processor), (...)"

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

9/59

In this agreement, it is indicated that,

"The purpose of the Agreement is to establish the legal regime applicable to the processing of personal data that is processed or may be processed by the data processor, by virtue of the service provision contracts that are signed between the parties, and that are under the ownership and control of the data controller.

The data processing activities provided for are those strictly necessary for the provision of the services provided in the main contract. The treatments that could be carried out by RSI, the type of information to be processed, and the categories of data subjects whose data could be processed are defined."

In the Agreement itself, it is indicated, in section 3 regarding the Obligations of the Data Processor, that:

"The Data Processor and all its personnel are obliged to:

- a) Use the personal data subject to processing, or those collected for their inclusion, only for the purpose of this assignment. Under no circumstances may they use the data for any other purpose, whether for their own or for third parties. To carry out any other activity aimed at the processing or use of the data files of the Data Controller, prior written consent from the Data Controller will be necessary.
 - b) Process the data in accordance with the instructions of the Data Controller. (...)
- (...)"

Regarding the notification of "data security breaches," it is specified in section 3.3 that:

"The Data Processor shall notify the Data Controller, without undue delay, and in any case, before the maximum period of 36 hours, and through the DPO, of any data security breaches under its responsibility of which it becomes aware, along with all relevant obligations for the documentation and communication of the incident. (...)"

Section 3.4 regarding security measures adds that:

"The Data Processor, in accordance with the provisions of Article 32, shall apply those technical and organizational measures appropriate to ensure an adequate level of security in relation to the risk of processing detected in each case, considering the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the variable probability and severity risks for the rights of individuals at any given time.

In any case, it must implement mechanisms equivalent to those used by the Data Controller to:

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

10/59

- a. Ensure the permanent confidentiality, integrity, availability, and resilience of the processing systems and services.
- b. Restore the availability and access to personal data quickly in the event of a physical or technical incident.
- c. Regularly verify, evaluate, and assess the effectiveness of the technical and organizational

measures implemented to ensure the security of the processing.

d. Pseudonymize and encrypt personal data, where applicable.

The technical and organizational measures to be implemented by the Processor are reflected in Annex B of this agreement - "Security Measures."

The Processor is authorized to subcontract the companies reflected in Annex A of the Agreement - "Subcontracting." The subcontractor, who also has the status of Processor, is equally obliged to comply with the obligations established in the Agreement for the Processor and the instructions issued by the Controller.

Regarding the obligations of the Controller, it is indicated in section 4 of the Agreement:

"It is the responsibility of the Controller:

- a) To provide the Processor with the necessary data for the provision of the service.
- b) If legally required, to carry out a data protection impact assessment of the processing operations to be carried out by the Processor.
- c) To carry out the necessary prior consultations.
- d) To ensure, prior to and throughout the processing, compliance with the GDPR by the Processor.
- e) To supervise the processing, including conducting inspections and audits." (the underlining is ours)

In section 5, the DPO of the Processor and the Controller is identified respectively.

Regarding the BCE (...):

"Identification A.A.A.

Contact ***EMAIL.1.

Regarding RURAL SERVICIOS INFORMATICOS, S.L., the DPO is recorded as:

"Identification C.C.C.

Contact ***EMAIL.2

Section 6 of the Agreement addresses "Liability," stating,

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

11/59

"If the Processor, or in its case, the contractors, breach this Agreement or the applicable regulations by determining the purposes and means of the processing, they will be considered responsible for the processing concerning said processing.

In the event that a supervisory authority sanctions the Controller as a direct consequence of the Processor's failure to comply with the stipulations of this Agreement, the Processor shall indemnify the Controller as stipulated in the liability clause of the current framework contract between the parties." (the underlining is ours)

THIRD:

In the "Agreement to modify the data protection clause of the service provision contracts," signed between BCE and RSI, signed in Madrid on 13/9/2018, Annex B - Security Measures to the Agreement to modify the data protection clause of the service provision contracts states that RSI has the following certifications:

(...)

Furthermore, in the "Agreement to modify the data protection clause of the service provision contracts," it is indicated that RSI has the following measures:

(...)

FOURTH:

On December 12, 2022, a personal data breach of CAJA RURAL BCE was reported to the Division of Technological Innovation of this Agency, with entry number REGAGE22e00057420153. This notification was sent by RSI, the Processor for BCE. Attached to this notification is the "Security Incident Analysis Report."

On 12/01/2023, BCE made an additional notification to that described in the previous section, with entry number REGAGE23e00002252732.

FIFTH:

BCE had the electronic banking application called Ruralvía Clásica for the purpose of providing online banking services to its customers.

(...)

On April 14, 2023, in response to the request made by the AEPD, RSI responded that:

(...)

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

12/59

SIXTH:

Regarding the establishment of a banner in the Ruralvía Clásica application that linked to the new NBE application and its operation, the "Security Incident Analysis Report," dated December 9, 2022, which RSI provided concerning the personal data breach of BCE, states:

(...)

Additionally, on April 14, 2023, in response to the request made by the AEPD within the framework of the preliminary investigation proceedings, RSI responded that:

(...)

RSI, in its submission dated October 11, 2023, Response 3 Complaint AEPD of entry REGAGE23e00068900170, indicates that,

(...)

SEVENTH:

(...)

On April 14, 2023, in response to the request made by the AEPD within the framework of the preliminary investigation proceedings, a document 9 titled "Web Application Audit" was submitted, in which it is indicated (...).

EIGHTH:

(...)

NINTH:

Regarding how the personal data breach occurred, on April 14, 2023, RURALVÍA, in response to the information request made by this Agency, states the following,

(...)

Additionally, in the "Final Security Incident Analysis Report," dated December 30, 2022, which RSI provided concerning the personal data breach of BCE, it is indicated in section 1.4.2, "How the problem was detected or how it happened?," that:

(...)

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

13/59

TENTH:

Likewise, in the "Final Security Incident Analysis Report," dated December 30, 2022, which RSI provided regarding the personal data breach of BCE, it is explained in section 1.4.1, "What happened?," that the personal data breach occurred due to a vulnerability (...), indicating that:

(...)

ELEVENTH:

Regarding the attack pattern used by the cybercriminal, on April 14, 2023, in response to the request made by the AEPD within the framework of the preliminary investigation actions by RSI, it is indicated that,

(...)

The same provision is contained in section 1.4.2 of the “Final Security Incident Analysis Report,” dated December 30, 2022, which RSI provided regarding the personal data breach of BCE.

TWELFTH:

Regarding the causes that allowed the personal data breach, in the “Final Security Incident Analysis Report,” dated December 30, 2022, which RSI provided regarding the personal data breach of BCE, it is indicated in section 3, “Analysis of Causes,” that:

(...)

THIRTEENTH:

In response to the information request made by the AEPD within the framework of the preliminary investigation actions, RSI responded on May 26, 2023, providing as document 8 an email dated September 28, 2022, prior to the occurrence of the highest volume of accesses (between November 10 and 23 of the same month) and the detection of the personal data breach, sent by (...).

In the same sense, as indicated, on April 14, 2023, in response to the request made by the AEPD within the framework of the preliminary investigation actions, RSI responded that,

(...)

On April 14, 2023, in response to the request made by the AEPD within the framework of the preliminary investigation actions, a document 9 titled “Web Application Audit” was submitted, in which it was indicated that,

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

14/59

(...)

FOURTEENTH:

On April 14, 2023, in response to the request made by the AEPD within the framework of the preliminary investigation actions, a document 9 titled “Web Application Audit” was submitted, in which ***TOOL.1 was examined.

(...)

FIFTEENTH:

Regarding the detection of the personal data breach, in the “Final Security Incident Analysis Report,” dated December 30, 2022, which RSI provided regarding the personal data breach of BCE, it is indicated in section 1.4.1, “What happened?”, that:

(...)

Therefore, although the breach was detected on December 7, 2022, prior accesses to that date are confirmed, noting that the highest volume of accesses occurred between November 10 and November 23, 2022.

Regarding the measures adopted on November 23, 2022, the aforementioned document indicates that,

(...)

Therefore, these measures were adopted before the personal data breach was detected (on December 7, 2022) and as a consequence of actions to increase the security of electronic banking.

SIXTEENTH:

Regarding the mitigating measures applied after the personal data breach, in the “Final Security Incident Analysis Report,” dated December 30, BCE states that,

(...)

SEVENTEENTH:

Subsequently, within the framework of the definitive implementation of the new NBE application, a series of actions are carried out, as noted in the “Final Security Incident Analysis Report,” dated December 30, 2022, which RSI provided regarding the personal data breach of BCE,

(...)

C/ Jorge Juan, 6

www.aepd.es
28001 – Madrid
sedeagpd.gob.es
15/59

EIGHTEENTH:

Regarding the personal data accessed by the attacker, the "Final Incident Analysis Report," dated December 30, 2022, provided by RSI in relation to the personal data breach of BCE, indicates which personal data may have been accessed,

(...)

NINETEENTH:

The breach notification forms accompanying the Security Incident Report prepared in all cases by RURAL SERVICIOS INFORMÁTICOS, S.L., the data processor, as stated in the preliminary investigation report dated November 27, 2023, determine that the number of individuals affected by the personal data breach of BCE is 18 clients.

TWENTIETH:

During the evidence gathering period referred to in the Tenth Fact, BCE provided an email sent authorizing the communication of the breach to the data processor (RSI) for notification of the breach to the AEPD:

From: (...) bce

Sent: Wednesday, December 14, 2022 11:56

To: DPO Entities; (...)

Subject: RE: INCIDENT RURALVÍA 0198

Good afternoon D.D.D., 5/11/24, 10:21

RE: INCIDENT RURALVÍA 0198: E.E.E. –

(...) Thank you very much for your email. After discussing with F.F.F. and reviewing the communication model you sent to the Agency, we request the communication of the security breach for Banco Cooperativo Español. I will send you the data you requested (...) from the Entity.

Regarding the communication of the same to the affected clients, we hope you will send us the draft of the letter for review and, if applicable, communication to our clients, which we will do, as F.F.F. has indicated to me, ourselves.

I still need to review the security incident report you have prepared. As soon as I can do it, I will let you know.

Thank you very much and best regards, E.E.E.

TWENTY-FIRST:

According to the documentation provided by BCE in the allegations, the business volume (gross margin) of BCE during the fiscal year 2022 amounts to €89,518,000.

LEGAL GROUNDS

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

16/59

I Competence

According to the powers granted by Article 58.2 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), to each supervisory authority and as established in Articles 47, 48.1, 64.2, and 68.1 of Organic Law 3/2018, of December 5, on Personal Data Protection and the guarantee of digital rights (hereinafter, LOPDGDD), the Director of the Spanish Data Protection Agency is competent to initiate and resolve this procedure.

Furthermore, Article 63.2 of the LOPDGDD states that: "The procedures processed by the Spanish Data Protection Agency shall be governed by the provisions of Regulation (EU) 2016/679, by this organic law, by the regulatory provisions issued in its development and, as long as they do not contradict them, subsidiarily by the general rules on administrative procedures."

II Preliminary Issues

Below is a list of the relevant legal concepts for this Proposal for Resolution, in accordance with the definitions in Article 4 of the GDPR (the relevant parts are highlighted):

"Article 4 Definitions

For the purposes of this Regulation, the following definitions shall apply:

(...)

1) "personal data": any information relating to an identified or identifiable natural person ("the data subject"); an identifiable natural person is one who can be identified, directly or indirectly, in particular by reference to an identifier, such as a name, an identification number, location data, an online identifier, or one or more factors specific to the physical, physiological, genetic, mental, economic, cultural, or social identity of that natural person;

(...)

2) "processing": any operation or set of operations performed on personal data or sets of personal data, whether by automated means or not, such as collection, recording, organization, structuring, storage, adaptation or alteration, retrieval, consultation, use, communication by transmission, dissemination, or otherwise making available, alignment, combination, restriction, erasure, or destruction;

The processing in this case has consisted of a set of operations for the retrieval and consultation of the personal data of the data subjects.

7) "data controller" or "controller": the natural or legal person, public authority, service, or other body that, alone or jointly with others, determines the purposes and means of the processing; if the law of the Union or of the Member States...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

17/59

determines the purposes and means of processing, the data controller or the specific criteria for its appointment may be established by Union law or the laws of the Member States;

The legal entity that determines the purposes and means of processing is BCE, as the provider of banking services, and the interested parties in this case are the clients who are linked to the banking entity through a contract. BCE collects the clients' data and decides on the purposes and means of the set of operations carried out on personal data through automated procedures.

8) "data processor" or "processor": the natural or legal person, public authority, service, or other body that processes personal data on behalf of the data controller;

(...)

BCE has commissioned RURALVÍA S.L., by contract dated 13/9/2018, to execute the necessary security measures for the set of automated operations for processing the personal data of clients, within the framework of its banking service contracts.

12) "personal data breach": any breach of security that leads to the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or unauthorized communication or access to such data;

A personal data breach has occurred due to unauthorized access by a third party (a hacker) to the personal data of BCE's clients.

The entity carries out this activity in its capacity as data controller, as it is the one who determines the purposes and means related to the processing of personal data, pursuant to Article 4.7 of the GDPR. Therefore, if it decides the "why" and the "how" personal data should be processed, it must assume its responsibility.

Furthermore, the data controller must also be responsible for implementing the technical and organizational measures that ensure the security of personal data when carrying out the processing. And be able to demonstrate compliance with the GDPR and the LOPDGDD.

In this case, there is a security incident, categorized as a personal data breach, involving unauthorized

access to personal data.

It should be noted that the identification of a personal data breach does not directly imply the imposition of a sanction by this Agency, as it is necessary to analyze the diligence of controllers and processors and the security measures applied.

Among the principles of processing provided for in Article 5 of the GDPR, the integrity and confidentiality of personal data are guaranteed in paragraph 1.f). In turn, the security of personal data is regulated in Articles 32 and 33 of the GDPR, which govern the security of processing, notification to the supervisory authority, and communication to the data subject, respectively.

As previously mentioned, it is presumed that the data controller is the entity that has the true capacity to exercise control over the data, who determines the why and how the data should be processed.

III Description of the personal data breach

BCE had an electronic banking application called Ruralvía Clásica for the purpose of providing online banking services to its clients.

For a client to enter the Ruralvía Clásica application and log in, they needed to enter their identifier, password, and NIF.

(...)

IV Violation of Article 5.1.f) of the GDPR.

Article 5.1.f) "Principles relating to processing" of the GDPR states:

"1. Personal data shall be:

(...)

f) processed in a manner that ensures appropriate security of personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage, through the application of appropriate technical or organizational measures ('integrity and confidentiality')."

(...)

The facts revealed in this procedure constitute a personal data breach consisting of a loss of confidentiality of personal data, considering that the regulations on the protection of personal data have been violated. The present facts have the data controller, BCE, as the party being claimed, as determined in the proven facts.

Thus, as stated in the seventeenth proven fact, regarding the personal data accessed by the attacker, the "Security Incident Analysis Report Final Report," dated December 30, 2022, indicates that,

(...)

Although the personal data breach was detected on December 7, 2022, prior accesses to that date are confirmed, with the highest volume of accesses occurring between November 10 and November 23, 2022.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

19/59

In this regard, in the aforementioned report dated December 30, 2022, as stated in the proven facts eighth and fourteenth, it is indicated in section 1.4.2, How was the problem detected or how did it happen?, that:

(...)

The attacker was able to access the personal data of BCE customers due to the lack of appropriate technical and organizational measures prior to the occurrence of the personal data breach.

First, it should be noted that, as stated in the proven fact eleventh, regarding the causes that allowed the personal data breach, in the "Final Incident Analysis Report," dated December 30, 2022, in section 3, "Cause Analysis," it states:

(...)

Second, in the proven fact fifteenth, the implemented mitigating measures are recorded, which highlight the absence of appropriate technical and organizational measures to prevent the occurrence of the breach, emphasizing, for such purposes,

(...)

In conclusion, and in accordance with all that has been indicated, it has been established that the violation of the principle of confidentiality that indeed occurred, as the attacker accessed multiple personal data (...) of BCE, was possible due to the lack of appropriate technical and organizational measures revealed by the aforementioned vulnerabilities.

The documentation in the file provides clear evidence that BCE violated Article 5.1.f) of the GDPR, "Principles relating to processing," by failing to adequately ensure the confidentiality and integrity of personal data as a result of the security breach that occurred.

In accordance with the evidence available in this proposal for resolution of the sanctioning procedure, it is considered that the known facts constitute an infringement attributable to BCE for violation of Article 5.1.f) of the GDPR.

V Qualification for the infringement of Article 5.1.f) of the GDPR

The aforementioned infringement of Article 5.1.f) of the GDPR constitutes the commission of the infringements classified in Article 83.5 a) of the GDPR, which considers that the infringement of "the basic principles for processing, including the conditions for consent under Articles 5, 6, 7, and 9" is punishable, in accordance with paragraph 5 of the aforementioned Article 83 of the cited Regulation, "with administrative fines of up to €20,000,000 or, in the case of an enterprise, an amount equivalent to 4% at most of the total annual global turnover of the previous financial year, opting for the higher amount."

The LOPDGDD in its Article 71, Infringements, states that: "Acts and conduct referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those contrary to this organic law, constitute infringements."

And in its Article 72, it considers for the purposes of prescription that they are: "Very serious infringements:

1. According to what is established in Article 83.5 of Regulation (EU) 2016/679, the following are considered very serious and will prescribe in three years: infringements that involve a substantial violation of the articles mentioned therein and, in particular, the following:

(...)

a) The processing of personal data violating the principles and guarantees established in Article 5 of Regulation (EU) 2016/679.

(...)

VI Proposal for sanction for the infringement of Article 5.1.f) of the GDPR

In order to establish the administrative fine that should be imposed, the provisions contained in Articles 83.1 and 83.2 of the GDPR must be observed, which state:

"1. Each supervisory authority shall ensure that the imposition of administrative fines under this Article for the infringements of this Regulation indicated in paragraphs 4, 5, and 6 is, in each individual case, effective, proportionate, and dissuasive.

2. Administrative fines shall be imposed, depending on the circumstances of each individual case, as an additional or substitute measure to those contemplated in Article 58, paragraph 2, letters a) to h) and j). In deciding the imposition of an administrative fine and its amount in each individual case, the following shall be duly taken into account:

a) the nature, gravity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing operation in question as well as the number of data subjects affected and the level of damage suffered;

b) the intentionality or negligence in the infringement;

c) any measures taken by the controller or processor to mitigate the damage suffered by the data subjects;

d) the degree of responsibility of the controller or processor, taking into account the technical or organizational measures they have applied pursuant to Articles 25 and 32;

e) any previous infringement committed by the controller or processor;

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

- f) the degree of cooperation with the supervisory authority in order to remedy the infringement and mitigate the possible adverse effects of the infringement;
- g) the categories of personal data affected by the infringement;
- h) the manner in which the supervisory authority became aware of the infringement, in particular whether the controller or processor reported the infringement and, if so, to what extent;
- i) when the measures indicated in Article 58(2) have been previously ordered against the controller or processor in relation to the same matter, compliance with such measures;
- j) adherence to codes of conduct under Article 40 or to certification mechanisms approved under Article 42; and
- k) any other aggravating or mitigating factor applicable to the circumstances of the case, such as the financial benefits obtained or the losses avoided, directly or indirectly, through the infringement.

In relation to point k) of Article 83.2 of the GDPR, the LOPDGDD, in its Article 76, "Sanctions and corrective measures," establishes that:

"2. In accordance with the provisions of Article 83.2.k) of Regulation (EU) 2016/679, the following may also be taken into account:

- a) The ongoing nature of the infringement.
- b) The connection of the infringer's activity with the processing of personal data.
- c) The benefits obtained as a result of the commission of the infringement.
- d) The possibility that the conduct of the affected party may have induced the commission of the infringement.
- e) The existence of a merger by absorption after the commission of the infringement, which cannot be attributed to the absorbing entity.
- f) The impact on the rights of minors.
- g) Having, when not mandatory, a data protection officer.
- h) The voluntary submission by the controller or processor to alternative dispute resolution mechanisms, in cases where there are disputes between them and any interested party."

According to the transcribed provisions, for the purpose of determining the amount of the sanction to be imposed in this case for the infringement of Article 5.1.f) of the GDPR, classified under Article 83.5.a) of the GDPR for which BCE is held responsible, the following concurrent factors are considered:

- The nature, severity, and duration of the infringement; the facts revealed affect a basic principle related to the processing of personal data, such as confidentiality and integrity, which the regulation penalizes with the utmost severity as it allows, as a consequence of the personal data breach, access to personal data by unauthorized third parties, with the harm that this may entail.
- The number of affected parties (...), to whom the personal data breach has been fully notified. Users have access in accordance with

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

Electronic Banking, which placed them in a position of special vulnerability as the attacker could access their economic data.

□

Regarding the level of damages caused: it must be considered high since, in addition to personal data (...), economic and financial data must be added, given that users who had access to Electronic Banking would have enabled access to this type of data (...). Additionally, it should be noted that this situation allows access to the data, which can lead to the materialization of the risk of identity theft, among others (Article 83.2.a) of the GDPR).

□

The intent or negligence in the infringement. There is a lack of diligence in complying with the obligations imposed by data protection regulations, as it allowed a cybercriminal to access personal data, violating its confidentiality; in this regard, the SAN of 17/10/2007 can be cited, which, although issued before the GDPR came into force, is perfectly extrapolable to the case we are analyzing. The ruling, after referring to the fact that entities whose activities involve continuous processing of customer and third-party data must observe an adequate level of diligence, specified that "(...) the Supreme Court has understood that there is negligence whenever a legal duty of care is disregarded, that is, when the offender does not behave with the required diligence. And in assessing the degree of diligence, the professionalism or lack thereof of the subject must be especially weighed, and there is no doubt that, in the case now examined, when the activity of the appellant involves constant and abundant handling of personal data, it must be insisted on the rigor and exquisite care to comply with the legal provisions in this regard" (Article 83.2.b) of the GDPR).

□

The activity of the allegedly infringing entity is linked to the processing of personal data of both clients and third parties. In the activity of the claimed entity, the processing of personal data is essential, so, given its purpose and business volume, the significance of the conduct subject to this claim is undeniable (Article 76.2.b) of the LOPDGDD in relation to Article 83.2.k).

For the purpose of deciding on the proposal for the fine and its amount, in accordance with the available evidence, taking into account the criteria of Article 83.2 of the GDPR regarding the infringement committed, violation of Article 5.1.f) of the GDPR, it is considered appropriate to propose a sanction of 6,159 euros.

The amount of the sanction recorded in the Initiation Agreement has been proportionally reduced based on the business volume recognized in the twenty-first proven fact.

VII Violation of Article 32.1 of the GDPR

Article 32 of the GDPR "Security of processing" establishes that:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

23/59

"1. Taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the varying probability and severity of risks to the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, which may include, among others:

- a) the pseudonymization and encryption of personal data;
- b) the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services;
- c) the ability to restore the availability and access to personal data quickly in the event of a physical or technical incident;
- d) a process for regularly verifying, assessing, and evaluating the effectiveness of the technical and organizational measures to ensure the security of processing.

2. In assessing the appropriateness of the level of security, particular consideration shall be given to the risks presented by the processing of data, in particular as a consequence of the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data.

3. Adherence to an approved code of conduct pursuant to Article 40 or to an approved certification mechanism pursuant to Article 42 may serve as an element to demonstrate compliance with the requirements set out in paragraph 1 of this article.

4. The controller and the processor shall take measures to ensure that any person acting under the authority of the controller or the processor and having access to personal data may only process such data on instructions from the controller, unless required to do so by Union or Member State law."

Having reviewed the allegations made by the respondent party, and in light of the same, having

reviewed the documentation in the administrative file and that provided by the respondent party, it is evident that all the technical and organizational security measures whose absence has been proven, directly enabling the personal data breach, do not constitute a violation, in this specific case, of Article 32 of the GDPR as the absence of other independent technical and organizational security measures unrelated to the personal data breach has not been demonstrated.

VIII Violation of Article 33 of the GDPR

Article 33 of the GDPR, "Notification of a personal data breach to the supervisory authority," establishes that,

"1. In the case of a personal data breach, the controller shall notify the competent supervisory authority in accordance with Article 55 without undue delay and, where feasible, no later than 72 hours after having become aware of it, unless the personal data breach is unlikely to result in a risk to the rights and freedoms of natural persons. If the notification to the supervisory authority does not take place within 72 hours, it shall be accompanied by the reasons for the delay.

2. The processor shall notify the controller without undue delay of any personal data breaches of which it becomes aware.

3. The notification referred to in paragraph 1 shall, at a minimum:

a) describe the nature of the personal data breach, including, where possible, the categories and approximate number of data subjects affected, and the categories and approximate number of personal data records affected;

b) communicate the name and contact details of the data protection officer or other contact point where more information can be obtained;

c) describe the possible consequences of the personal data breach;

d) describe the measures taken or proposed by the controller to remedy the personal data breach, including, where appropriate, the measures taken to mitigate the possible adverse effects.

4. If it is not possible to provide the information simultaneously, and to the extent that it is not possible, the information shall be provided in phases without undue delay.

5. The controller shall document any personal data breaches, including the facts relating to the breach, its effects, and the remedial measures taken. This documentation shall enable the supervisory authority to verify compliance with the provisions of this article."

On 21/10/2024, it was agreed to open a period for the practice of evidence in which point 3: It is agreed to require BCE to provide the following information and/or documentation:

"Provide documentation evidencing that, if applicable, it had instructed or given instructions to its processor for the notification to the AEPD of the personal data breach subject to this sanctioning file (Article 33 GDPR). Evidence of both the instruction and the..."

25/59

terms of this and its date. The result of these tests may lead to the conduct of others. In your response, you must indicate the reference of the file that appears in the heading of this document."

The respondent has submitted in response to this requirement on 11/5/2024, the following documents:

Document number 1: Email dated 14/12/2024, where RSI, in its capacity as data processor for BCE, communicated the security incident to the latter, indicating that they were preparing a report regarding it, outlining next steps (notification to the AEPD and communication to the affected parties) and requesting validation from BCE as the data controller.

Upon analyzing the documentation submitted by BCE referred to in the Twentieth Proven Fact, RSI (responsible declaration in a private document by the highest authority of the entity, based on a request for prior instructions from the data processor and with the immediate subsequent action of notifying the personal data breach to the AEPD) it is determined that the respondent has provided in response to the evidence practice carried out by this Agency on 5/11/2024 regarding the accreditation of the instructions given to its data processor, so that it could proceed to notify on its behalf to the AEPD of the personal data breach subject to the aforementioned procedure, in accordance with Article 33 of Regulation (EU) 2016/679 of the European Parliament and of the Council, of April 27, regarding the protection of natural persons with regard to the processing of personal data and on the free movement of such data (hereinafter "GDPR").

Therefore, it must be concluded that, after analyzing the investigated facts, the allegations made by

the respondent, and the evidence provided in the procedure, considering the concurrent circumstances in the specific case, the filing of the alleged infringement in relation to Article 33 of the GDPR would be appropriate.

IX Response to the allegations made regarding the initiation agreement

In relation to the allegations made by BCE regarding the initiation agreement, we proceed to respond to them in the order in which they are presented in their writing:

“FIRST. ON THE ACCUMULATION OF PROCEDURES AGAINST THE ENTITIES OF THE GROUP.”

1. Preliminary considerations

According to BCE: “All the initiation agreements in the files just referenced arise, as indicated, from the security breach analyzed by the Initiation Agreement” and subsequently states that “we are faced with a single fact, referring to a single breach, suffered during the development of the aforementioned tool carried out by RSI in its capacity as data processor and that, however, is fragmented by the AEPD into twenty-six differentiated procedures processed against twenty-six different entities.”

In response to these preliminary considerations, it should be noted that the respondent confuses the factors that determined the vulnerability being similar in all the procedures initiated by this Agency with the fact that only a single personal data breach has occurred.

We are dealing with incidents that have affected (...) which are completely independent, both legally and economically. Each of these entities is responsible for the data processing of its clients in a differentiated manner, and, consequently, there are as many personal data breaches as there are data controllers who have failed to comply with the obligations imposed by the GDPR. Each entity is responsible for the processing of its own data and regarding its own clients.

All the entities referred to by the respondent in their allegations had contracted with RSI, (...).

However, the fact that RSI was the same data processor for all the Entities does not determine that one can speak of “a single fact, referring to a single breach.”

Each entity, as the data controller of its clients, autonomously made the decision to contract with RSI as the data processor, for which each of them signed their own data processing agreement, on differentiated dates, signed by different persons with sufficient power for this in each of the rural banks and with reference to their different data protection delegates, who are not the same.

Furthermore, as also stated in the proven facts, both the “Security Incident Analysis Report,” dated December 9, 2022, and the “Final Security Incident Analysis Report,” dated December 30, 2022, were carried out individually for each of the rural banks, containing their own specificities.

Also, once the personal data breach occurred, the actions of each of the entities were not the same, with each acting autonomously, both regarding the AEPD (some banks have notified the personal data breach directly and others have entrusted their data processor to carry it out), as well as regarding their respective clients and independently of the actions of the others.

2. On the accumulation of administrative procedure files.

In this allegation, the respondent considers that: “The legal regime of the accumulation of procedures, as well as of processes, in the administrative sphere responds to the central idea of connectivity, that is, that the instruction work that must be carried out is favored by the appreciation in its entirety of the subject.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

27/59

raised and the possibility that the joint viewing work allows for a better assessment of the elements that enable the application of the norm to the specific case.”

Article 57 of the LPACAP regarding the accumulation of procedures establishes that:

“The administrative body that initiates or processes a procedure, regardless of the form of its initiation, may, ex officio or at the request of a party, order its accumulation with others that have substantial identity or intimate connection, provided that it is the same body that must process and resolve the procedure. No appeal shall proceed against the agreement of accumulation” (the underlining corresponds to the AEPD).

Consequently, both the administrative body that initiates the procedure and the one that processes it may order its accumulation with other procedures that have substantial identity or intimate connection, provided that it is the same body that must process and resolve the procedure.

Article 57 of the LPACAP grants administrative bodies the authority for better management of the procedures they process, allowing for their accumulation as long as there is substantial identity or intimate connection among them. Therefore, it is a possibility available to the Administration, which is not obliged to proceed with the accumulation if requested, although it is required to make a reasoned decision in this regard, as occurs in the present sanctioning procedure.

3. Response to the allegation seeking the accumulation of sanctioning procedures.

In this allegation, the responding party considers that: "The legal regime of the accumulation of procedures, as well as of processes, in the administrative sphere responds to the central idea of connectivity, that is, that the instructional work that must be carried out is favored by the appreciation of the issue raised as a whole and the possibility that the joint viewing work allows for a better assessment of the elements that enable the application of the norm to the specific case."

It should be noted that the claims of the responding party are not supported by Article 57 of the LPACAP, nor by any type of jurisprudence or doctrine, which attributes to accumulation the purpose of providing the decision-making body with a better assessment of the elements of the case.

The institution of accumulation is a technique of administrative simplification that allows the competent body to process and resolve in a main procedure the possibility of accumulating with those others that have substantial identity or intimate connection, for the purpose of simultaneous processing and resolution. The instrumental nature of accumulation is determined by the first limit established by Article 57 of the LPACAP, which is that the body "must be the same body that must process and resolve the procedure."

It is a procedural act that cannot be appealed, as established by Article 57 of the LPACAP itself, unlike what is established in Article 112.1 of the same norm, which does allow for the challenge of other procedural acts when these...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

28/59

"directly or indirectly decide the substance of the matter, determine the impossibility of continuing the procedure, produce defenselessness or irreparable harm to legitimate rights and interests."

However, when the LPACAP excludes the possibility of appeal, it is because it applies to the accumulation of procedures, as a procedural act, none of the assumptions of Article 112.1 of the LPACAP that we have just reproduced.

With these arguments as a starting point, the allegations made by the responding party must be completely dismissed, to which a concrete response will also be provided.

A) Existence of "intimate connection" or "substantial identity."

The responding party reiterates the idea referred to in the preliminary considerations of this FIRST allegation, stating that "a single breach of personal data security occurred, notified by each of the responsible parties (directly or through their data processor RSI)." It continues to assert that "the connectivity, in this case, derives from the fact that responsibility is to be clarified for twenty-six legal entities, but for the same event."

As already substantiated in the response to the preliminary considerations of this FIRST allegation, it cannot be said that there is a single breach of personal data; rather, as many breaches of personal data have occurred as there are entities, all of which are independent of each other, each responsible for its own processing and regarding its own clients, whose systems have suffered a security breach. For the responding party, there is a single event for which responsibilities can be demanded, the security incident in the field of information technology. However, beyond the breach of personal data itself, there has been a loss of confidentiality of the personal data of the clients of each of the entities, which cannot be encompassed as a single event or as the same event.

In the same way, the facts relating to the actions taken after each entity became aware of the security

breach must be differentiated. Some entities notified the AEPD directly of the breach, while in others, the communication was made by the data processor at the request of each of the data controllers (in different ways and at different times).

Finally, some entities communicated the loss of confidentiality of their personal data to the affected parties, complying with the obligation established in Article 34 of the GDPR, while other entities did not send any type of communication.

All these diverse factual elements determine that it cannot be said that, beyond the same IT vulnerability, there exists an “intimate connection” or “substantial identity” that justifies the accumulation of the procedures.

Regarding the ruling of the TSJ Castilla-La Mancha cited in the allegations, the following clarifications should be made:

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
29/59

1) There is no compliance with an obligation by several persons jointly, therefore the assumption of Article 28.3 of Law 40/15 does not apply.

According to Article 28.3 of Law 40/2015, of October 1: “When the fulfillment of an obligation established by a norm with the rank of Law corresponds to several persons jointly, they shall be jointly liable for the infringements that may be committed and for the sanctions that are imposed. However, when the sanction is monetary and it is possible, it shall be individualized in the resolution based on the degree of participation of each responsible party.”

In the present case, it cannot be said that there is joint liability, as it does not concern a joint obligation of BCE with the other entities referred to in its written allegations. The facts constituting the infringement attributed to BCE are in its capacity as the data controller, in accordance with the provisions of Article 4 of the GDPR, so the compliance with the principles and obligations established in the GDPR regarding the data processing of its clients corresponds to it individually, not jointly with the other entities, since, furthermore, there is no joint liability in the GDPR.

It should also be noted that the fine imposed on each entity depends on its own circumstances, such as the number of affected clients or its business volume.

The figure of joint controllers of the processing, regulated in Article 26 of the GDPR, would also not be applicable in this case, “when two or more controllers jointly determine the purposes and means of the processing, they shall be considered joint controllers of the processing.” The purposes and means of the processing have been determined by BCE independently of the other entities, in its capacity as the sole controller of the personal data of its clients.

Finally, the assumption described in the judgment does not apply to BCE in relation to the other entities, in which “the Administration imputes different forms of cooperation or collusion among the three defendants in relation to the same facts.” Here, there can be no talk of any type of cooperation or collusion in the facts, simply the responsibility of each of the Rural Savings Banks, and the relationship with the data processor, due to the regime established in the GDPR, according to which the controller, in this case, each of the Rural Savings Banks, has control and authority over the processing of personal data and assumes responsibility for compliance with the obligations imposed by the GDPR. For its part, the data processor (RSI) must only process the data according to the instructions received from the controller. It cannot determine the purposes and means of the processing; its function is to execute the processing as established by the controller.

2) The separate processing of the files does not prevent each entity from presenting its allegations.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
30/59

In the ruling of the TSJ of Castilla La Mancha referred to by BCE, in the Third Legal Basis, it is stated

that the plaintiff requested that all proceedings be consolidated in order to adequately exercise the right to defense, "...since they referred to the same facts, and it was expressly noted that processing them separately would constitute a serious violation of the right to defense as it would prevent knowledge of the allegations from the other parties involved and the documents they might submit, all of which could have implications for the legal qualification of the facts, the determination of the existence or non-existence of an infringement, and the identification of the responsible party."

The non-consolidation of proceedings cannot produce any of the harms mentioned in that paragraph of the ruling.

Regarding the documents submitted to the procedure, those related to the security incident, a series of documents were provided by the data processor during the investigative proceedings (let us remember that both the "Security Incident Analysis Report," dated December 9, 2022, and the "Final Security Incident Analysis Report," dated December 30, 2022, were prepared individually for each of the rural banks, containing their specificities) whose access to the affected entity has been guaranteed through the prior request for a copy of the file. Those documents submitted by the entities responsible for the processing, which affect them individually, will be taken into consideration in the corresponding procedure.

3) BCE reiterates the need for the "consolidated analysis of the files," when the ruling of the TSJ of Castilla La Mancha does not include this idea. The need for consolidation is based on considerations other than those expressed by BCE. As we have analyzed:

- Reference is made to access to the documents in the file that may be submitted by different responsible parties, a matter that we see is guaranteed here.
- The possibility of establishing joint liability is mentioned, which, as we have substantiated, does not apply under the regime established in the GDPR. We must not confuse joint liability under Article 28 of the LRJSP with the co-responsibility of Article 26 of the GDPR, which also does not apply in this case, since, as we stated, in no case are the other Rural Banks co-responsible for the processing of customer data of the other entities.
- There is no type of cooperation or collusion among the different Rural Banks in the facts. These figures must be dismissed due to the relationship among the Rural Banks, which are independent entities, each responsible for the processing of their customers, nor, as we have previously stated, regarding the special regime established by the GDPR concerning the relationship between the responsible party and the data processor.

B) That the same body is responsible for the processing and resolution of the procedure.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

31/59

The processing of the various sanctioning procedures corresponds to the same body, as indicated by BCE, which does not determine the mandatory nature of the decision to consolidate the procedures, especially when there are no circumstances that imply BCE's defenselessness.

4. Connectivity in the sanctioning field with the guarantees of Articles 24 and 25.1 of the Spanish Constitution.

In this allegation, BCE points out that the Constitutional Court has declared that both the substantive principles of Article 25.1 CE and the procedural guarantees of Article 24.2 CE are applicable, with certain nuances, to the exercise of sanctioning power.

4.1. General aspects related to the instruction and its essential functionality.

A) Linkage of the instruction as a consequence of the factual unity.

BCE cites a ruling from the Supreme Court, which states that "the initiation of a single sanctioning procedure for the commission of the same infringing act, with the aim of determining the degree of participation of each alleged responsible party in the commission of the infringement and ensuring that the resolution of the file is coherent..." According to BCE, "In this case, the appellant argued that, since two files were processed, each of the responsible parties was unaware of what was in the other that could benefit or harm them. This is a concrete example of the difficulties that arise in terms of the right

to defense in cases of separate processing."

As previously justified, there are as many breaches of personal data as there are responsible parties for the processing, and we cannot speak of a single infringing act, but rather of a series of infringing acts attributable to a series of independent entities concerning the processing for which they are responsible, regarding their clients; nor can we speak of "degree of participation" among the various entities, nor in relation to the responsible party-processor relationship.

Regarding the documents that are submitted to the procedure, those relating to the security incident, a series of documents were provided by the data processor during the investigation proceedings, whose access to all affected entities has been guaranteed by sending, upon request, a copy of the file.

Moreover, RSI submitted the "Security Incident Analysis Report," dated December 9, 2022, as well as the "Final Security Incident Analysis Report," dated December 30, 2022, in a manner individualized for each of the rural banks, containing their specificities.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

32/59

Those documents submitted by the entities responsible for the processing, which affect them individually, will be taken into consideration in the corresponding procedure. And those others that may constitute evidence relevant to the facts will be duly incorporated into the other official files, in accordance with the provisions of Article 75 of the LPACAP, "the necessary instructional acts for the determination, knowledge, and verification of the facts on which the resolution must be pronounced will be carried out ex officio."

B) Connectivity as a fundamental prerequisite for exercising the right to defense.

According to BCE, each of the sanctioning procedures becomes "sealed," and the evidence, allegations, and expert opinions presented in one cannot be presented contradictorily in another.

However, a paragraph from the ruling transcribed by BCE is fully applicable to respond to this allegation: "it is not specified to what extent their defense was 'harmed'," and to reject it, just as the STS understands "that the decision of the court of first instance is correct, which considers that the initiation of sanctioning files against each of the companies is justified... due to the clear differentiation of the conduct attributed and it has not been demonstrated that they have suffered real defenselessness - as reasoned in the contested ruling."

The Constitutional Court in its ruling No. 210/1999, of November 29, states that constitutionally relevant defenselessness is the situation in which, after the infringement of a procedural norm, one of the parties is prevented from exercising their right to defense by eliminating or limiting their power, either to assert rights and interests to be recognized, or to dialectically respond to opposing positions in the exercise of the principle of contracting.

As an essential characteristic of defenselessness, it must be material and not merely formal, that is, it is not sufficient to have a defect or procedural infringement; there must have been an effective and real right to defense (Constitutional Court ruling No. 90/1988, of May 13).

Well, beyond a generic allegation of the eventual defenselessness that could arise from the non-consolidation of the procedures, BCE is unable to present a single defect or procedural infringement that has effectively limited its right to defense, when the allegations presented by the affected Rural Banks regarding the security incident are substantially similar, and they have had access to all documentation that affects them in a common manner. In any case, the instructing body will incorporate into the procedure and inform BCE of any other documents that may constitute evidence relevant to the facts.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

33/59

4.2.- The intimate connection as a requirement for the individualization of responsibility for the same facts.

BCE argues that, since we are dealing with a single breach of personal data, the processing of separate procedures for each of the responsible entities may eventually lead to the determination of diverse responsibilities. The intimate connection translates into the principle of uniqueness in determining the concurrence of facts when, as BCE claims, it concerns unique facts that result in a single breach of personal data.

As previously motivated, it is not appropriate to speak of a single breach of personal data, but rather as many as there are data controllers who have suffered the security incident regarding their clients' data. There cannot be different degrees of responsibility between BCE and the other entities. Each of the data controllers will have a degree of responsibility that must be determined individually concerning compliance with data protection regulations, without any type of cooperation in the commission of the infringement among the different Rural Savings Banks that could determine different degrees of responsibility among the entities, as BCE claims.

BCE continues its reasoning by stating that "responsibility cannot be individualized without first objectifying the sanctioning reproach, and this cannot be projected in 26 procedures with their own dynamics, their own evidence...". Abstract arguments continue to be made, such as objectifying the sanctioning reproach, regarding its own dynamics and "its own evidence," when not even allegations have been made questioning the facts and the evidence contained in the initiation agreement, nor has a request for evidence in the procedure been made.

The fact that "a single investigation procedure" has been processed and that no request has been directed against the responsible data controllers but rather concerning the processor (RSI) does not imply the "unitary factual determination," as BCE argues. That the inspection actions were directed to require information from the data processor does not determine that subsequently a single procedure must be initiated to clarify the administrative responsibilities. It should be noted that Article 53, "Scope of the investigation activity," of the LOPDGDD does not impose that these must necessarily be carried out concerning the data controller. Therefore, there is no obligation to investigate all the controllers that carry out the processing in question. Inspectors can obtain evidence by consulting and requesting information from the data processor if they deem it appropriate.

4.3 Impact on the fundamental right to good administration

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

34/59

According to BCE, accumulation becomes an obligation in the event that its absence could harm the rights of the administered party, particularly those recognized in Article 24 of the Constitution, thereby violating the right to good administration as per Article 41 of the Charter of Fundamental Rights of the European Union.

In the previous allegations, the differences between the behaviors attributed to the Rural Savings Banks have been motivated, and it has been established that no type of defenselessness has been caused to BCE in the processing of this procedure, having had access to all documents in the file. In fact, BCE has not justified any type of defenselessness, nor does it point out any specific fact by which it has been caused defenselessness.

Finally, it is reiterated that we are not dealing with the same facts, but rather with the same technical problem that caused a security incident in the computer system of each of the responsible entities in relation to their processing of personal data (all of which are legally and economically independent from each other), which has produced a series of personal data security breaches, not a single personal data breach, but a personal data breach in each of the Rural Savings Banks, which result in the alleged commission of a series of infringements by each of the different data controllers in relation to their processing of personal data and the rights and freedoms of their clients.

"SECOND. THE NON-EXISTENCE OF CULPABILITY OF BCE IN THIS CASE"

BCE has invoked various arguments to justify the absence of culpability in its conduct.

Firstly, it states that it is outside the facts attributed to it, since in this case, the processing is carried out through a data processor; which, in turn, is the processor of the entities against which the proceedings are directed; and that the personal data protection regulations not only impose obligations related to compliance with the principle of confidentiality and the adoption of necessary security measures on the data controller but also, when the processing is carried out on behalf of the controller by a data processor, on the latter.

In this regard, it is worth recalling that the figure of the data processor responds to the need to address phenomena such as the outsourcing of services by companies and other entities, so that in those cases where the data controller entrusts a third party with the provision of a service that requires the processor to process personal data on its behalf, the processing or operations of the processing are carried out by the processor, in the name and on behalf of the controller, as if it were the latter who is carrying it out.

Therefore, the existence of a data processor depends on a decision made by the data controller, who may decide to carry out the processing themselves.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

35/59

certain treatment operations or to contract the entirety or part of the treatment with a processor.

That is to say, the processor, in order to be one, does not hold any personal interest regarding the outcome of the treatment subject to the contract, without prejudice to the economic compensation it receives for the service rendered, which is what occurs in the present case. Processors have no personal interest; they act on behalf and in the name of the controller, following their orders and for their purposes, and this is what determines that they are processors from the outset.

This determines that the controller is liable for actions contrary to the GDPR carried out by its processors, unless the latter have acted as true controllers of the treatment, deciding on the purposes and means of the treatment, a situation that has not occurred in the present case.

Thus, the CJEU ruling of December 5, 2023, issued in case C-683/21, regarding the question of whether an administrative fine can be imposed under Article 83 of the GDPR on a controller in relation to the treatment operations carried out by a processor, determines that,

“83 Regarding, secondly, the question of whether an administrative fine can be imposed under Article 83 of the GDPR on a controller in relation to the treatment operations carried out by a processor, it should be recalled that, according to the definition set out in Article 4, point 8, of the GDPR, a processor is understood to be ‘the natural or legal person, public authority, service, or other body that processes personal data on behalf of the controller.’

84 Given that, as indicated in paragraph 36 of this judgment, a controller is responsible not only for all personal data processing it carries out itself but also for processing carried out on its behalf, an administrative fine can be imposed on that controller under Article 83 of the GDPR in a situation where personal data is subject to unlawful processing and where it is not the controller, but a processor it has engaged, that has carried out the processing on its behalf.

85 However, the liability of the controller for the behavior of a processor cannot extend to situations where the processor has processed personal data for its own purposes or where it has processed such data in a manner incompatible with the framework or modalities of processing as determined by the controller or in a manner that cannot reasonably be considered to have been consented to by that controller. Indeed, in accordance with Article 28, paragraph 10, of the GDPR, the processor must, in that case, be considered a controller with respect to that processing.” (the emphasis is ours)

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

36/59

In addition to the above, we must add the recent SAN of February 8, 2024, rec. 0002250/2021,

regarding TELEFÓNICA MÓVILES ESPAÑA S.A.U, in which it is determined that, “Indeed, the appellant company is responsible for the processing, as it determines the purpose and means of the processing carried out for the purposes indicated in its Privacy Policy: ‘At Movistar, we process customer or user data for the provision of the service, as well as for other purposes that the customer allows or authorizes in the terms informed in this Privacy Policy or in the specific Conditions of each contracted Movistar Product or Service.’

Whereas the companies ATENTO TELESERVICIOS ESPAÑA, S.A.U., CATHPONE-NET, S.L., and THADER TELECOMUNICACIONES S.L., are considered data processors.

What has been stated derives from the contracts signed by the plaintiff with the aforementioned companies.

...

Indeed, it has not been demonstrated that the aforementioned companies, as data processors for the plaintiff, have determined the purposes and means of the processing, nor have they used the data of the customers of the plaintiff for their own purposes, nor have they interacted with third parties outside the structure and commercial name of the appellant company, but rather have acted under the name of the plaintiff to fulfill its purposes, using its systems to carry out operations with customers.

Therefore, it is not possible to invoke Article 28.10 of the GDPR for a presumed attribution of responsibility to the processors, which would also imply the exoneration of the data controller, that is, of the company here appealing. On the other hand, according to the aforementioned contracts, there is a clause that passes on to them the possible sanctions that the plaintiff company may suffer for non-compliance with data protection obligations.” (the underlining is ours)

On the other hand, the Guidelines 7/2020 of the EDPB on the concepts of “data controller” and “data processor” in the GDPR, version 2.0 Adopted on July 7, 2021, determine that,

“30 Following the line of the fact-based approach, the word ‘determine’ means that the entity that truly exerts a decisive influence over the purposes and means of the processing is the controller. Generally, the processing contract establishes who is the determining party (the data controller) and who is the party that follows the instructions (the data processor). Even when the data processor...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

37/59

If a service is offered that is defined in advance in a specific manner, the data processor must present a detailed description of the service to the data controller, who must make the final decision on the approval of how the processing will be carried out and request any changes deemed necessary. Furthermore, the data processor cannot modify the essential elements of the processing at a later time without the approval of the data controller.

...

39. The question is where to draw the line between the decisions reserved for the data controller and those that can be left to the discretion of the processor. It is evident that decisions regarding the purpose of the processing must always correspond to the data controller.

40. Regarding the determination of the means, a distinction can be made between essential and non-essential means. Essential means are traditionally and inherently reserved for the data controller. These must be determined mandatorily by the data controller, although the determination of non-essential means can also be left to them. Essential means are closely linked to the purpose and scope of the processing, such as the type of personal data processed (“What data will be processed?”), the duration of the processing (“How long will the data be processed?”), the categories of recipients (“Who will have access to the data?”), and the categories of data subjects (“To whom do the processed personal data belong?”). In addition to being related to the purpose of the processing, essential means are closely tied to the question of whether the processing is lawful, necessary, and proportionate. Non-essential means are related to more practical aspects of the processing itself, such as the choice of a particular type of hardware or software or the decision regarding the details of security measures, which can be left to the data processor.

41. Although decisions regarding non-essential means can be left to the data processor, the data controller must still stipulate certain elements in the contract with the processor: for example, regarding the security requirement, all measures required under Article 32 of the GDPR may be mandated. The contract must also establish that the data processor will assist the data controller in ensuring compliance with, for example, the provisions of Article 32. In any case, the data controller remains responsible for implementing appropriate technical and organizational measures to ensure and be able to demonstrate that the processing is compliant with the Regulation (Article 24). To this end, the data controller must take into account the nature, scope, context, and purposes of the processing, as well as the risks to the rights and freedoms of natural persons. For this reason, the data controller must have complete information about the means used, as this will enable them to make an informed decision in this regard. To demonstrate the legality of the processing, it is advisable to document this in the contract or another instrument.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

38/59

legally binding between the controller and the processor, at least the necessary technical and organizational measures.

...

74. The GDPR establishes specific obligations that directly bind processors, as specified in section 1 of subsection II of these guidelines. It is possible to hold a processor liable or sanction them when they fail to comply with such obligations or act outside or against the legal instructions of the controller.

...

80. Secondly, the processing must be carried out on behalf of a controller, but not under their direct authority or control. Acting "on behalf of" someone means serving the interests of another and refers to the legal concept of "delegation." In the case of data protection regulations, the role of the processor is to apply the instructions given by the controller, at least concerning the purposes of the processing and the essential elements of the means. The legitimacy of the processing under Article 6 and, if applicable, Article 9 of the Regulation derives from the activity of the controller, and the processor must only process the data following the instructions given by the controller. Nevertheless, as previously indicated, the instructions of the controller may leave some margin of discretion regarding how best to serve their interests, allowing the processor to choose the most appropriate technical and organizational means.

81. Acting "on behalf of" someone also means that the processor cannot carry out the processing for their own purposes. As stipulated in Article 28, subsection 10, the processor will infringe the GDPR when they do not adhere to the instructions of the controller and begin to determine their own purposes and means of processing. In such cases, the processor will be considered responsible in relation to that processing and may be sanctioned for failing to comply with the instructions of the controller." (the underlining is ours)

Well, in the specific case being examined, and in light of the documentation in the file, it is noted that, for the provision of IT services, BCE has entered into an "Individualized and Specific Service Provision Contract" with RSI.

Additionally, it has also entered into the framework of the previous agreement the "Agreement to Modify the Data Protection Clause of the Service Provision Contracts between BCE and RURAL SERVICIOS INFORMÁTICOS, S.L." related to BCE, which was signed on 13/9/2018, by A.A.A. and B.B.B., on behalf of BCE (controller of the processing).

In this regard, in this "Agreement to Modify the Data Protection Clause of the Service Provision Contracts between BCE and RURAL SERVICIOS

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

"INFORMÁTICOS, S.L." identifies BCE as the data controller and RSI as the data processor.

Furthermore, in this "Amendment Agreement to the Data Protection Clause of the Service Provision Contracts between BCE and RURAL SERVICIOS INFORMÁTICOS, S.L.", the data processing activities that may be carried out by RSI on behalf of BCE, the types of information to be processed, and the categories of data subjects whose data may be processed are defined.

Additionally, it is determined that the security measures that must be applied by RSI to ensure an adequate level of security in accordance with Article 32 of the GDPR are those established in Annex B of the "Amendment Agreement to the Data Protection Clause of the Service Provision Contracts between BCE and RURAL SERVICIOS INFORMÁTICOS, S.L."

It should also be noted that Section 6 of the Agreement on "Liability" states that,

"If the Processor, or in its case, the contractors, breach this Agreement or the applicable regulations when determining the purposes and means of processing, they will be considered responsible for the processing concerning such processing.

In the event that a supervisory authority sanctions the Data Controller as a direct consequence of the Processor's failure to comply with the stipulations of this Agreement, the Processor shall indemnify the Data Controller as stipulated in the liability clause of the current framework contract between the parties" (the underlining is ours).

This implies, conversely and in accordance with data protection regulations, the aforementioned judgments, and Guidelines 7/2020, that the data controller is responsible for the actions carried out by its data processor unless the latter determines the purposes and means, resulting in the fact that this last issue has not been substantiated in the processed procedure.

Therefore, in accordance with the above, BCE is the data controller for the processing being carried out; it is the one who has decided to entrust a data processor to carry it out on its behalf and for its account, it is the entity that has the true capacity to exercise control over the processing of personal data, determining which personal data will be processed on its behalf and for its account, the why and how these should be processed, as it defines the purpose of the personal data processing that its activity encompasses and chooses the means it deems appropriate.

And according to all the above and for the specific case, BCE is responsible for the infringement of the GDPR even if the incident occurred within its data processor.

In this regard, the Initial Agreement itself indicates in Section 4 regarding the Obligations of the Data Controller that:

"It is the responsibility of the data controller:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

40/59

- a) Deliver to the Data Processor the necessary data for the provision of the service.
- b) In the event that it is legally required, conduct an impact assessment on the protection of personal data of the processing operations to be carried out by the Data Processor.
- c) Carry out the necessary prior consultations.
- d) Ensure, both prior to and throughout the processing, compliance with the GDPR by the Data Processor.
- e) Supervise the processing, including conducting inspections and audits." (the underlining is ours)

This directly relates to the principle of proactive responsibility of the data controller as provided in Article 5.2 of the GDPR, which states that "the data controller shall be responsible for compliance with the provisions of paragraph 1 and be able to demonstrate it ('proactive responsibility')." This means that the controller must ensure the effective application of the principles of processing both at the time of determining the means of processing and during the processing itself, whether they carry out the processing of personal data directly or entrust a data processor to do it on their behalf (for the purposes of data protection legislation, it is the same), through the implementation of a series of

technical and organizational measures of all kinds, which must be subject to periodic review and updating. This implies that the aforementioned controller is the one who assumes their own responsibility by directing, reviewing, and coordinating the processing, including that of the personnel and that of the data processor providing services to them.

Opinion 3/2010, from the Article 29 Working Party (WP29) - WP 173 - issued during the validity of the repealed Directive 95/46/EC, whose provisions are currently applicable, states that the “essence” of proactive responsibility is the obligation of the data controller to implement measures that, under normal circumstances, ensure that the data protection rules are complied with in the context of processing operations and to have available documents that demonstrate to data subjects and supervisory authorities what measures have been adopted to achieve compliance with data protection rules.

For these purposes, consideration is given to what is stated in Recital 74 of the GDPR, “The responsibility of the data controller must be established for any processing of personal data carried out by them or on their behalf. In particular, the controller must be obliged to implement appropriate and effective measures and must be able to demonstrate the compliance of processing activities with this Regulation, including the effectiveness of the measures. Such measures must take into account the nature, scope, context, and purposes of the processing, as well as the risk to the rights and freedoms of natural persons.” (the underlining is ours)

Completing the above and in development of Article 5.2 of the GDPR, Articles 24 and 25 of the same legal text should be cited, with the latter indicating regarding “Data protection by design and by default” that the fundamental right to the protection of...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

41/59

Personal data is much more than mere technology, as its focus is on the risks to the rights and freedoms of the data subjects arising from the processing of personal data.

“1. Taking into account the state of the art, the cost of implementation, and the nature, scope, context, and purposes of the processing, as well as the risks of varying probability and severity that the processing entails for the rights and freedoms of natural persons, the data controller shall implement, both at the time of determining the means of processing and at the time of the processing itself, appropriate technical and organizational measures, such as pseudonymization, designed to effectively apply the principles of data protection, such as data minimization, and integrate the necessary safeguards into the processing, in order to comply with the requirements of this Regulation and protect the rights of the data subjects.

2. The data controller shall implement appropriate technical and organizational measures to ensure that, by default, only personal data that is necessary for each specific purpose of the processing is processed...”

The ECB seems to maintain that the responsibility lies with the data processor with whom it entered into a contract and under which it was obliged to implement appropriate security measures according to the risk; however, it is worth recalling that the personal data breach occurred as a result of the ECB's decision (...), subscribing to the corresponding data processing agreement with RSI where the ECB established the appropriate conditions.

Moreover, this is in addition to what this Agency has motivated in previous paragraphs regarding the fact that the ECB has determined the purposes and means of processing, that it is the data controller, that it is responsible for the personal data breach in this case due to the processing actions carried out by its data processor on its behalf, and that it is subject to the obligations of the GDPR, especially regarding proactive responsibility.

This is the responsibility of the ECB because it is the data controller and is obligated to integrate and deploy data protection within everything that constitutes its organization, in all its areas of action,

whether affecting its employees or its data processors. It must be kept in mind that ultimately the determining purpose is to ensure the protection of the data subject, as the focus is on the risks to the rights and freedoms of the data subjects arising from the processing of personal data carried out by the data controller.

Therefore, the data controller must conduct a risk analysis of the rights and freedoms of natural persons in data processing, implementing appropriate technical and organizational measures to apply the principles of data protection and integrate the necessary safeguards into the processing, in order to comply with the requirements of the GDPR, being able to demonstrate that the processing is in accordance with the provisions of the aforementioned regulation. And in light of the principle of

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

42/59

proactive responsibility (art. 5.2 GDPR), the data controller must be able to demonstrate that it has taken into account all the elements provided for in the GDPR. Therefore, all of this merely reflects a lack of diligence on the part of the investigated entity in ensuring adequate security in relation to the risks of the data processing it carries out. In this regard, it should not be forgotten that the affected database contains personal data of thousands of customers, which constitutes large-scale processing, to which access is also made from web applications, that is, from the internet, with a very significant exposure surface, posing greater risks to the data subjects, which requires appropriate technical and organizational measures of all kinds, including security measures, specifically aimed at ensuring that there is no unlawful access to such personal data.

As has been demonstrated and argued throughout this sanctioning procedure, it is considered that appropriate security measures were not implemented in this case to ensure the security of the personal data of the customers, which resulted in unlawful access to the personal data of the BCE customers. Therefore, liability is not being demanded solely as a consequence of a result caused by a cyberattack.

It is much more than that; it is a failure to comply with the obligations imposed by the GDPR.

Therefore, it is emphasized that the data controller must establish clear modalities for such assistance in its relationship with the data processor and provide precise instructions to the data processor on how to comply with them appropriately and document it beforehand through a contract or another (binding) agreement, and also subsequently during the validity of the same and verify at all times during the execution of the contract its compliance in the manner established therein.

It suffices to bring to mind the content of the STS 1562/2020, of June 15, 2020, rec. 601/2019, which states the following:

“In this regard, the Judgment of the Supreme Court of June 5, 2004, which confirms, in cassation for Unification of Doctrine, that of this AN of October 16, 2003, echoing the arguments made by this Chamber refers to the differentiation of two controllers based on whether the decision-making power is directed at the file or the data processing itself. Thus, the file controller is the one who decides the creation of the file and its application, as well as its purpose, content, and use, that is, who has decision-making capacity over all the data recorded in that file. The data processor, however, is the subject to whom decisions regarding the specific activities of a particular data processing can be attributed, that is, regarding a specific application. This would involve all those cases in which the decision-making power must be differentiated from the material execution of the activity that integrates the processing. With this, as also argued by the STS of April 26, 2005 (cassation for unification of doctrine 217/2004), the Spanish legislator aims to adapt to the requirements of Directive 95/46/EC, which aims to provide a legal response to the phenomenon, which each

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

43/59

It is increasingly common in the so-called outsourcing of IT services, where multiple operators act, many of whom are insolvent, created with the aim of seeking impunity or irresponsibility for those who follow in the subsequent links of the chain. Currently, the new Regulation (EU) 2016/679 of the European Parliament and of the Council of April 27, 2016, regarding the protection of natural persons with regard to the processing of personal data (which repeals Directive 95/46/EC and is directly applicable from May 25, 2018) also distinguishes between the roles of the data controller and the data processor. The former is defined in paragraph 7) of Article 4 as "a natural or legal person (...) who determines the purposes and means of the processing." And the data processor is defined in paragraph 8) of the same Article 4 as one who "processes personal data on behalf of the data controller."

This is in relation to Articles 24 and 28 of the same European Data Protection Regulation. The data controller and the data processor are undoubtedly also responsible for violations regarding data protection, within this new regulatory framework, in accordance with the provisions of Article 82.2 of the aforementioned Regulation (EU) 2016/679, which states: Any controller participating in the processing operation shall be liable for damages caused if that operation does not comply with the provisions of this Regulation. A processor shall only be liable for damages caused by the processing when it has not complied with the obligations of this Regulation specifically directed to processors or has acted outside or against the legal instructions of the controller. It follows from all the above that the involvement, in this case, of a data processor ZZZZ does not exempt the entity XXXX, now the appellant, from liability, and this is despite the strength of the clauses in the contract and annex signed by both companies (proven facts 9 and 10) in that the personal data processed was for the purpose of carrying out an advertising campaign regarding car and motorcycle insurance marketed by (XXXX), ultimately benefiting said XXXX, being this acting entity the one that ultimately determines the purposes and means of the repeated data processing, therefore it cannot be exempted from liability. The Supreme Court continues, in relation to the possible exemption of liability claimed regarding what was agreed in the "data processor" contract, as follows:

"The sanctioned conduct of obstruction or impediment by XXXX of its client's exercise of the right to object to the processing of their data is manifested in that said company did not adopt any measures or precautions to prevent the sending of advertisements to the email addresses of its client by those companies to which it entrusted the execution of the advertising campaigns.

The adoption of the necessary measures or precautions to ensure the effectiveness of the right to object to the processing of their data by XXXX, as the data controller, persists even if the advertising campaigns do not...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

44/59

They are carried out based on the data from their own files, but rather with databases from other companies contracted by XXXX, and in this case, it was established that the appellant did not communicate to the companies with which it contracted the provision of advertising services the complainant's opposition to receiving advertising from the Mutual, nor did it ultimately take any measures to ensure the exclusion of its client from the advertising mailings contracted with third entities."

Regarding the application of the principle of culpability in the field of sanctioning law regulated by the GDPR, the investigated entity invokes the doctrine established by the CJEU ruling of December 5, 2023 (case C-807/21, Deutsche Wohnen SE and Staatsanwaltschaft Berlin).

It is pertinent to ask what the parameters of due diligence that the investigated entity should have observed concerning the examined conduct are. The answer is that the diligence it should have observed is that which was necessary to comply with the obligations imposed by Articles 5.2, 24, and 25 of the GDPR, in light of the doctrine of the National Court and the jurisprudence of the Supreme Court.

The SAN ruling of October 17, 2007 (rec. 63/2006) is fully applicable to the case, which, after referring to the fact that entities whose activities involve continuous processing of data from clients and third parties must observe an adequate level of diligence, states:

“[...] the Supreme Court has understood that there is negligence whenever a legal duty of care is neglected, that is, when the offender does not behave with the required diligence. In assessing the degree of diligence, the professionalism or lack thereof of the subject must be especially weighed, and there is no doubt that, in the case now examined, when the activity of the appellant involves constant and abundant handling of personal data, it must insist on rigor and exquisite care to comply with the legal provisions in this regard.”

Furthermore, the National Court in matters of personal data protection has declared that “simple negligence or failure to comply with the duties imposed by the Law on those responsible for files or data processing to exercise extreme diligence is sufficient...” (National Court Judgment of June 29, 2001).

Regarding the allegation that the breach of personal data occurred within the framework of the data processing for which RSI was responsible, to the extent of carrying out the investigative actions exclusively with that entity, it should be noted that the preliminary investigative actions are precisely carried out to clarify the facts and circumstances of what happened, gathering more information in order to determine whether or not there is a possible infringement of data protection regulations.

In this sense, the initiation of preliminary investigations and their execution, a power of the AEPD, does not prejudge anything but allows for the determination of the events that occurred and the gathering of necessary information wherever it may be found to determine whether there are indications of an infringement or not. Even after such investigation, it may be that the proceedings are archived.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

45/59

actions for understanding, in view of the information gathered, that there are no indications of infringement. This has not occurred in the present case.

Consequently, the allegations must be dismissed since the investigated entity has violated the obligations imposed by the GDPR as the data controller for the processing carried out on its behalf and for its account, in relation to the responsibilities required of every data controller under Article 24 of the GDPR. Therefore, the allegations must be dismissed, emphasizing that the arguments presented do not undermine the essential content of the infringement declared nor do they constitute sufficient justification or exculpation.

“THIRD. ON THE IMPACT ON THE PRINCIPLES OF SANCTIONING LAW DERIVED FROM THE INTERPRETATION MADE BY THE AEPD”

BCE considers that it has not committed any infringement of data protection regulations, much less the simultaneous infringement of Articles 5.1 f) and 32 of the GDPR, as the triple identity of subject, fact, and protected legal interest occurs; there is no doubt that in this case the principle of non bis in idem should apply, imposing only the sanction for Article 5.1.f) as it is the more serious of the two alleged infringements.

And in the event that the AEPD finds a violation, it should subsidiarily recognize a medial concurrence as one of the infringements is subsumed and embedded in the other, according to what is provided in Article 29.5 of the LRJSP, “When the commission of one infringement necessarily derives from the commission of another or others, only the sanction corresponding to the most serious infringement committed shall be imposed.”

“1. Violation of the principle of non bis in idem in the application of Articles 5.1 f) and 32 of the GDPR”

In this regard, and concerning this allegation made by BCE against the initiation agreement, it should be noted that since the filing of the initially imputed infringement of Article 32 of the GDPR has been proposed, it is no longer necessary to respond to these allegations, as the imputation of the

infringement of Article 5.1.f) of the GDPR no longer coincides with the imputation of the infringement of Article 32 of the GDPR.

“FOURTH. ON THE ALLEGED VIOLATION OF ARTICLE 32.1 OF THE GDPR”

BCE has stated that the AEPD considers the alleged violation of Article 32 of the GDPR to be “evidenced,” meaning it considers the supposed insufficiency of the security measures adopted to be evident as a result of the occurrence of the personal data breach, making exclusive reference to the report on the breach contained in the administrative file, overlooking all the measures adopted as well as the audit carried out, and misinterpreting what occurred in the RSI systems.

Well, as indicated, upon reviewing the allegations made by the responding party, and in consideration of them, reviewing the documentation in the administrative file and that provided by the responding party, it is evident that all the technical and organizational security measures whose absence has been proven have had a direct impact on the personal data breach, without there having been a violation, in this specific case, of Article 32 of the GDPR as the absence of other independent technical and organizational security measures from the personal data breach has not been demonstrated.

Regarding the sufficiency of the security measures, in relation to the breach of Article 5.1.f) of the GDPR, we refer to what has already been indicated in the legal basis IV of this resolution proposal, which explains and details why they were neither sufficient nor appropriate.

Furthermore, it should be noted that it is true that both prior to and after the security incident, the investigated entity conducted audits and reviews by third-party specialists aimed at detecting vulnerabilities exclusively concerning the security of the information systems; but it is also true that despite the existence of such investigations, controls, and checks, they were unable to locate and reveal the existing vulnerabilities, as evidenced in the proven facts.

On the other hand, BCE claims that RSI holds various security certifications, referenced in the third proven fact of this resolution proposal.

Article 28 of the GDPR, on the Data Processor, in its paragraph 5, establishes that:

“5. The adherence of the data processor to a code of conduct approved under Article 40 or to a certification mechanism approved under Article 42 may be used as an element to demonstrate the existence of the sufficient guarantees referred to in paragraphs 1 and 4 of this article.”

In this sense, to demonstrate that processors offer the suitability and guarantees required by the GDPR, adherence to a certification mechanism can be used as an additional element to indicate the existence of sufficient guarantees to apply appropriate technical and organizational measures to protect personal data.

And this is because, in addition to the fact that a data processor has been certified in data protection, this certification does not absolutely prove that the sufficient guarantees in relation, in this case, to the provision of Article 28.1 of the GDPR, have been implemented and are effectively acting throughout the entire processing cycle and during the time in which the processing is taking place.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

47/59

In matters of data protection, this type of instrument serves as a mechanism for voluntary compliance in which specific rules are established to contribute to the proper application of the GDPR and the LOPDPGDD.

According to the GDPR, the data controller must adopt appropriate measures, including the selection of processors, in such a way that guarantees and is able to demonstrate that the processing is carried out in accordance with the GDPR (principle of active accountability).

It is true that the certifications that the data processor RSI appears to hold are mentioned in the data processing agreement; however, let us note that all the certifications listed in the third proven fact are not the certificates provided for in either Article 28 or Article 42 of the GDPR; they are not certifications in data protection, but rather certifications of information security or related to other obligations that must be fulfilled by the controller or the processor based on regulations other than data protection.

Thus, in the "Agreement to Modify the Data Protection Clause of Service Provision Contracts," signed

between BCE and RSI, in its "Annex B - Security Measures to the Agreement to Modify the Data Protection Clause of Service Provision Contracts," it is indicated that RSI holds the following certifications:

(...)

Furthermore, the mention of these certifications in the processing agreement is not accompanied by the certification itself - for the purpose of verifying that it has indeed been certified and to see exactly what it is certified for, when it was certified, and whether the certification was still valid at the time of the personal data breach (since certifications have a validity period) - this certification is not for data protection.

In this regard, the report from the Legal Advisory Office 170/2018 of the AEPD establishes the difference between information security and the protection of personal data. It indicates that, "Prior to analyzing the specific issue raised in the consultation, this Legal Advisory Office finds it appropriate to make a preliminary reference (...).

Regarding information security, it encompasses the set of techniques and measures aimed at ensuring the confidentiality, integrity, and availability of information and data important to any organization, regardless of their format. (...)

In contrast, the protection of personal data of natural persons is configured as a true fundamental right that finds its basis in Article 18.4 of the Spanish Constitution, according to which

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

48/59

"the law shall limit the use of information technology to guarantee the honor and personal and family privacy of citizens and the full exercise of their rights." This has been recognized by our Constitutional Court, highlighting in Judgment 94/1998, of May 4, that the aforementioned article 18.4 "not only entails a specific instrument for the protection of citizens' rights against the wrongful use of information technology but also enshrines an autonomous fundamental right to control the flow of information concerning each person - 'privacy' according to the neologism stated in the Explanatory Memorandum of the LORTAD - whether or not it belongs to the strictest realm of intimacy, in order to preserve the full exercise of their rights."

This is reflected in the Preamble of the Organic Law Project on Personal Data Protection and Guarantee of Digital Rights, which is transcribed below for its clarity:

"The protection of individuals in relation to the processing of personal data is a fundamental right protected by article 18.4 of the Spanish Constitution. Thus, our Constitution was a pioneer in recognizing the fundamental right to personal data protection when it stipulated that 'the law shall limit the use of information technology to guarantee the honor and personal and family privacy of citizens and the full exercise of their rights.' It echoed the work developed since the late 1960s in the Council of Europe and the few legal provisions adopted in countries around us.

The Constitutional Court stated in its Judgment 94/1998, of May 4, that we are faced with a fundamental right to data protection which guarantees individuals control over their data, any personal data, and over its use and destination, to prevent the illicit trafficking of such data or harm to the dignity and rights of those affected; thus, the right to data protection is configured as a citizen's power to oppose the use of certain personal data for purposes other than those that justified its acquisition. For its part, in Judgment 292/2000, of November 30, it considers it as an autonomous and independent right that consists of a power of disposition and control over personal data that empowers the individual to decide which of those data to provide to a third party, whether the State or a private individual, or which this third party may collect, and that also allows the individual to know who possesses that personal data and for what purpose, being able to oppose such possession or use. At the legislative level, the specification and development of the fundamental right of protection of individuals in relation to the processing of personal data took place in its origins through the approval of Organic Law 5/1992, of October 29, regulating the automated processing of personal data, known as LORTAD. Organic Law 5/1992 was replaced by Organic Law 15/1999, of December 5, on personal

data protection, in order to transpose Directive 95/46/EC of the European Parliament and of the Council, of October 24, 1995, regarding the protection of individuals with regard to the processing of personal data and the free movement of such data. This organic law represented a

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

49/59

second milestone in the evolution of the regulation of the fundamental right to data protection in Spain, and it was complemented by an increasingly abundant jurisprudence from the contentious-administrative jurisdiction.

On the other hand, it is also included in Article 8 of the Charter of Fundamental Rights of the European Union and in Article 16.1 of the Treaty on the Functioning of the European Union. Previously, at the European level, the aforementioned Directive 95/46/EC had been adopted, which aimed to ensure that the guarantee of the right to personal data protection did not constitute an obstacle to the free movement of data within the Union, thus establishing a common space for the guarantee of the right that simultaneously ensured that in the case of international data transfers, their processing in the destination country was protected by safeguards adequate to those provided for in the directive itself. In this same sense, Regulation (EU) 2016/679 of the European Parliament and of the Council, of April 27, 2016, on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation, GDPR), states that its purpose is “to protect the fundamental rights and freedoms of natural persons and, in particular, their right to the protection of personal data” (Article 1.2), highlighting in its Recital 1 that “the protection of natural persons in relation to the processing of personal data is a fundamental right” and in its Recital 10 that “to ensure a consistent and high level of protection of natural persons and to eliminate obstacles to the free movement of personal data within the Union, the level of protection of the rights and freedoms of natural persons with regard to the processing of such data must be equivalent in all Member States. It must be ensured throughout the Union that the application of the rules for the protection of the fundamental rights and freedoms of natural persons in relation to the processing of personal data is consistent and homogeneous.” Consequently, the right to the protection of personal data of natural persons is a fundamental right and, therefore, situated at the highest level of legal protection, which is currently regulated directly by community legislation, establishing the aforementioned GDPR a set of principles, rights, obligations, and an organizational structure aimed at guaranteeing this fundamental right. Among these, information security appears as an additional obligation of the controllers and processors, who must apply appropriate technical and organizational measures to ensure a level of security appropriate to the risk, which will include, among other factors, “the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services” and “the ability to restore the availability and access to personal data quickly in the event of a physical or technical incident” (Article 32.2. b) and c) of the GDPR).

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

50/59

Therefore, there is no doubt that the guarantee of the security of personal data acquires special significance regarding its protection, but without being limited exclusively to the realm of the security of such information, as the protection of personal data has a much broader scope that encompasses, as we mentioned, a set of principles, rights, and obligations that are much more extensive. (the underlining is ours)

This issue is substantial since the certification mentioned in the service contract does not serve as an element to “demonstrate the existence of sufficient guarantees referred to in paragraphs 1 and 4” of Article 28 of the GDPR, as it does not pertain to data protection. The difference in approach between

mere information security and data protection is extremely important, as while the former focuses exclusively on the security of information, the risk-based approach inherent to the GDPR (which is much broader as it focuses on the risks to the rights and freedoms of data subjects arising from the processing of personal data) is centered on natural persons, with security being just one obligation among those of the GDPR to achieve the protection of natural persons in the terms of recitals, notably 1 and 10, as well as in accordance with the provisions of Article 1 of the GDPR.

Within the management of GDPR compliance lies risk management, on which information security pivots, and not the other way around.

(...)

BCE argues that the security measures initially implemented by RSI are outlined in the service contract signed with RSI and that the attackers could have legitimate credentials for access and that the attack is not due to the weakness of the implemented systems.

As a preliminary matter, we must refer to the proven facts and the description of the personal data breach to understand how and why the personal data breach occurred.

Regarding the security measures included in the "Amendment Agreement for the Data Protection Clause of the Service Provision Contracts," when referencing the security measures, there is a reference to those outlined in Annex B - Security Measures to the Amendment Agreement for the Data Protection Clause of the Service Provision Contracts.

Well, from a detailed examination of the citation of the same, as we are unaware of their development in relation to the specific measures implemented, we can again verify that they are measures that refer generally to information security and not to data protection (...), a substantially different issue from data protection. (...) A policy is a central and guiding instrument of an organization in which the responsible party addresses its objectives and establishes procedures, resources, and mechanisms to carry it out, requiring subsequent detailed development. It is not the same to address mere security of

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

51/59

the information that addresses the protection of a fundamental right such as data protection, taking into account the focus and purpose of each of them.

Furthermore, the fact that a contract for processing includes a list of measures (specifically, in this case, information security measures) does not imply that these measures guarantee appropriate security as determined by Article 5.1.f) of the GDPR, because it is necessary to consider the approach to the protection of the rights and freedoms of the data subjects, and the measures implemented do not necessarily serve to fulfill that objective if they have not been designed and implemented from the perspective required by the GDPR.

"FIFTH. ON THE ALLEGED VIOLATION OF ARTICLE 5.1.f) OF THE GDPR"

BCE considers the contradiction in which the Initial Agreement incurs by stating that "the identification of a personal data breach does not imply the direct imposition of a sanction by this Agency, as it is necessary to analyze the diligence of controllers and processors and the security measures applied," when it subsequently understands that Article 5.1.f) has been infringed as a consequence of the mere fact that the breach has occurred.

On this particular matter, we refer to the legal basis IV explaining the concurrence of the infringement of Article 5.1.f) of the GDPR in this specific case, where it is detailed that the infringement has not been committed by the mere result of loss of confidentiality, even when it is a result-based infringement.

The Judgment of the Constitutional Court (STC) 292/2000, in its analysis of the "content" of the fundamental right to data protection, refers to the power of disposition and control that belongs to the data subject over the possible use or uses of their data by a third party. Legal Basis seventh states: "[...] it turns out that the content of the fundamental right to data protection consists of a power of disposition and control over personal data that empowers the individual to decide which of those data to provide to a third party, whether the State or a private individual, or which this third party may

collect, and that also allows the individual to know who possesses that personal data and for what purpose, being able to oppose that possession or use. These powers of disposition and control over personal data, which are part of the content of the fundamental right to data protection, are legally specified in the authority to consent to the collection, obtaining, and access to personal data, its subsequent storage and processing, as well as its possible use or uses by a third party, whether the State or a private individual.”

The obligation of confidentiality that Article 5.1.f) of the GDPR imposes on the data controller is an obligation of result, such that for the provision to be considered infringed, the confidentiality of the data must be breached.

As specified in the Supreme Court ruling of February 15, 2022, rec. of cassation 7359/2020,

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

52/59

“The obligation to adopt the necessary measures to guarantee the security of personal data cannot be considered an obligation of result, which implies that once a personal data breach occurs, there is liability regardless of the measures adopted and the activity carried out by the data controller or processor.

In obligations of result, there is a commitment to achieve a specific objective, ensuring the achievement or proposed result, in this case, guaranteeing the security of personal data and the non-existence of breaches or security failures (...). (the emphasis is ours)

It should be noted that the data controller incurs in contradiction when, on the one hand, it considers that there has been no violation of data protection regulations and estimates that everything should be redirected to the filing of the case, while on the other hand, it confirms and indicates that it is evidenced in the file “that the attacker could access the data, but in no case alter them,...”; (...).

Regarding the allegations reiterated by the respondent party that the infringements attributed concerning Article 5.1.f) and 32 of the GDPR are identical since we are dealing with the same fact subject to double imputation, we refer to what has already been indicated in previous legal bases regarding the proposal to file the infringement of Article 32 of the GDPR.

In light of the above, it is evidenced that BCE has violated the principle of confidentiality and integrity of the data, a principle enshrined in Article 5.1.f) of the GDPR, an infringement classified in Article 83.5.a) of the GDPR.

“SIXTH. ON THE ALLEGED VIOLATION OF ARTICLE 33 OF THE GDPR”

Regarding the allegations made by the complainant concerning the imputation of Article 33 of the GDPR, a response is no longer necessary, as, as stated in the proven facts and in the preceding legal bases, the filing of the initially imputed infringement is proposed in light of the specific circumstances of the previously expressed case.

“SEVENTH. VIOLATION OF THE PRINCIPLE OF PROPORTIONALITY IN THE DETERMINATION OF SANCTIONS”

BCE has alleged that in the event that it is considered that there has been an infringement of data protection regulations, particular consideration should be given in determining the sanction that may be imposed based on the application of the principle of proportionality.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

53/59

Firstly, BCE has claimed that its gross margin for 2022 is €89,518,000, instead of the €218,000,000 reflected in the initiation agreement. BCE substantiates the validity of this amount by providing audited annual accounts that confirm the indicated figure. For this reason, the claimed gross margin is accepted as the basis for calculating the penalty, and the amount of the fine is recalculated

accordingly.

It should be noted that Article 83.1 of the GDPR states that “Each supervisory authority shall ensure that the imposition of administrative fines pursuant to this Article for the infringements of this Regulation referred to in paragraphs 4, 5, and 6 shall in each individual case be effective, proportionate, and dissuasive.”

Fines, therefore, as deduced from the invoked provision, must be effective, proportionate, and dissuasive to achieve the intended purpose of the GDPR.

It is true that for this system to function with all its guarantees, several elements must be deployed in an integral and complete manner. The application of rules external to the GDPR regarding the determination of fines in each of the Member States applying their national law, whether due to aggravating or mitigating circumstances not provided for in the GDPR—or in the LOPDGDD in the Spanish case as permitted by the GDPR itself—would undermine the effectiveness of the system, losing its meaning, its teleological purpose, and the will of the legislator, resulting in fines imposed for different infringements ceasing to be effective, proportionate, and dissuasive. In this way, it would also deprive the interested parties of the effective guarantee of their rights and freedoms, weakening the uniform application of the GDPR. The mechanisms for protecting the rights and freedoms of citizens would be diminished, which would be contrary to the spirit of the GDPR.

The GDPR is endowed with its own principle of proportionality that must be applied in its strict terms. Regarding the principle of proportionality of sanctions, the National Court has indicated in numerous rulings that the principle of proportionality cannot be exempt from judicial review, as the margin of appreciation granted to the Administration in imposing sanctions within the legally established limits must be developed by weighing, in any case, the concurrent circumstances, in order to achieve the necessary and due proportion between the alleged facts and the responsibility required, given that any sanction must be determined in accordance with the severity of the infringement committed and according to a criterion of proportionality in relation to the circumstances of the act. Thus, proportionality constitutes a normative principle that is imposed on the Administration and that reduces the scope of its sanctioning powers.

Well, in accordance with the circumstances present in this case, which have been meticulously and appropriately evaluated, this resolution does not violate the principle of proportionality in determining the imposed sanctions, resulting in a balanced and proportionate response to the severity of the infringement committed, the importance of the facts, as well as the circumstances taken into account to grade the sanction, without any reasons being appreciated that further justify the

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

54/59

the reduction made, especially considering the amount to which such sanctions may rise in accordance with Article 83.5 of the GDPR, which provides for fines of up to €20,000,000 for violations of Article 6.1 of the GDPR, or, in the case of a company, an amount equivalent to a maximum of 4% of the total annual global turnover of the previous financial year, opting for the higher amount.

In the present case, the entity under investigation is a large company within its sector of activity; according to the twenty-first proven fact, its turnover (gross margin) during the 2022 financial year amounted to €89,518,000, resulting in the fine imposed for the violation of Article 5.1(f) of the GDPR being €6,159, which is at the lower end of the possible administrative fine that could be imposed on the data controller and far from the maximum of 4% of the total annual global turnover of the previous financial year considering the turnover.

- BCE considers regarding the circumstance derived from the nature, severity, and duration of the violation that the mere reference to the provision subject to the violation is taken as an aggravating factor.

However, such an argument cannot be accepted as inconsistent; in fact, what is being highlighted is that the violation of Article 5.1(f) affects one of the basic principles on which data protection regulations are based, confidentiality, and this breach is exacerbated and aggravated by the number of individuals

affected by the incident, the damages caused (irreversible loss of power and control over personal data by clients), and its duration, as (...).

- BCE considers regarding the intent or negligence in the violation that the lack of diligence in its actions is exclusively due to its status as a financial entity, and, in truth, the cited assertion is surprising.

Considering that BCE's conduct involves the element of culpability, which is essential to impose liability for sanctions, in this case, it is also specified in a very serious lack of diligence in complying with the principle of confidentiality of personal data as has been demonstrated throughout the procedure.

RSI has indicated that:

(...)

Furthermore, the lack of diligence demonstrated in the infringing conduct for which it is held responsible must be classified as very serious; BCE is obliged under Article 5.2 of the GDPR to carry out the appropriate activity to comply with the principles of data protection, particularly, the principle of confidentiality, and to be in a position to demonstrate its compliance.

- BCE considers that taking its banking activity into account as an aggravating factor is a sort of objective aggravating factor; firstly, it is not a matter related to the specific activity carried out by a particular entity, but rather that

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

55/59

The aggravating factor provided for in Article 76.2.b) of the LOPDGDD applies when the infringer's activity is linked to the processing of personal data, and it is obvious that, in relation to the present data controller, its activity, in this specific banking case, is clearly linked, directly, to multiple processing of personal data affecting thousands of clients.

In this regard, the Audiencia Nacional has considered it correct to appreciate the aggravating factor provided for in Article 76.2.b) of the LOPDGDD as long as the aforementioned link exists, and it has considered this in numerous rulings, including the one dated 04/07/2024 (rec. 382/2022), which states regarding the cited circumstance that:

“As well, the aggravating factor of the continued nature of the infringement, included in Article 76.2.a) of Organic Law 3/2018, of December 5, on the Protection of Personal Data and the guarantee of digital rights, can be appreciated, referring to it when we analyze the application of the GDPR to the infringement at hand. As well as the appreciation of the link between the infringer's activity and the processing of personal data (Article 72.2.b) of Organic Law 3/2018, of December 5), due to the fact that the activity of the appellant is linked to the processing of data from both clients and third parties; this link is well-known since the entity, due to its activity, is in permanent contact with clients and third parties handling a large volume of data, which imposes a greater duty of diligence” (the emphasis is ours).

Finally, BCE considers that the AEPD has not taken into account elements to mitigate its responsibility, such as evidentiary elements that demonstrate compliance with the highest standards in security matters, nor the fact that the measures adopted were subjected to a system of periodic auditing or that RSI resolved the vulnerability that constituted the security breach; it is sufficient to refute what has been stated by referring to the content of the proven facts and regarding the last issue raised, to refer to what the data processor itself indicates in its writing notifying the personal data breach, dated 14/12/2022, and the writing of 10/01/2023 transferring the final report, in which it responds to the following questions:

- Could the breach have been avoided by adopting any additional security measures?

Yes

- Did the incident occur due to any failure, deficiency, or non-compliance with implemented security measures?

Yes

And regarding the actions taken after the incident:

- Have you adapted/improved your security procedures and policies?

No

Therefore, the allegation made regarding the violation of the principle of proportionality cannot be accepted.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

56/59

In light of the above, the following

PROPOSAL FOR RESOLUTION

is issued that the Director of the Spanish Agency for the Protection of Data sanctions

BANCO COOPERATIVO ESPAÑOL, S.A. with NIF A79496055,

- For the alleged infringement of Article 5.1.f) of the GDPR, classified in Article 83.5.a) of the GDPR, with a fine of €6,159 (SIX THOUSAND ONE HUNDRED FIFTY-NINE euros).

That the Director of the Spanish Agency for the Protection of Data proceeds to archive, regarding BANCO COOPERATIVO ESPAÑOL, S.A. with NIF A79496055,

- For the alleged infringement of Article 32.1 of the GDPR, classified in Article 83.4.a) of the GDPR.

- For the alleged infringement of Article 33 of the GDPR, classified in Article 83.4.a) of the GDPR.

Likewise, in accordance with the provisions of Article 85.2 of the LPACAP, it is informed that you may, at any time prior to the resolution of this procedure, make voluntary payment of the proposed sanction, which will imply a reduction of 20% of the amount thereof. With the application of this reduction, the total sanction would be established at €4,927 (FOUR THOUSAND NINE HUNDRED TWENTY-SEVEN euros) and its payment will imply the termination of the procedure, without prejudice to the imposition of the corresponding measures. The effectiveness of this reduction will be conditioned upon the withdrawal or renunciation of any action or administrative appeal against the sanction.

In the event that you choose to proceed with the voluntary payment of the amount specified above, in accordance with the provisions of the cited Article 85.2, you must make it effective by depositing it into the restricted account No. IBAN: ES00-0000-0000-0000-0000-0000 (BIC/SWIFT Code:

CAIXESBBXXX) opened in the name of the Spanish Agency for the Protection of Data at the banking entity CAIXABANK, S.A., indicating in the concept the reference number of the procedure that appears in the heading of this document and the reason, for voluntary payment, for the reduction of the amount of the sanction. Likewise, you must send the proof of payment to the General Subdirector of Inspection to proceed to close the file.

In virtue of the above, you are notified of all that precedes, and the procedure is made known so that within TEN DAYS you may allege whatever you consider in your defense and present the documents and information you deem pertinent, in accordance with Article 89.2 of the LPACAP.

R.R.R.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

57/59

INSPECTOR/INSTRUCTOR

ANNEX

Index of file EXP202400072

(...)

>>

SECOND: On December 21, 2024, the party being claimed has proceeded to pay the fine in the amount of 4,927.00 euros, making use of the reduction provided for in the resolution proposal

transcribed above.

THIRD: The payment made entails the waiver of any action or appeal in the administrative route against the fine, in relation to the facts referred to in the resolution proposal.

LEGAL GROUNDS

I

Competence

In accordance with the powers granted to each supervisory authority by Article 58.2 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and as established in Articles 47, 48.1, 64.2, and 68.1 of Organic Law 3/2018, of December 5, on the Protection of Personal Data and guarantee of digital rights (hereinafter, LOPDGDD), the Presidency of the Spanish Agency for Data Protection is competent to initiate and resolve this procedure.

Furthermore, Article 63.2 of the LOPDGDD states: "The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, by this organic law, by the regulatory provisions issued in its development, and, to the extent that they do not contradict them, subsidiarily by the general rules on administrative procedures."

II

Termination of the procedure

Article 85 of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter LPACAP), under the heading "Termination in sanctioning procedures" provides as follows:

"1. Once a sanctioning procedure has been initiated, if the offender acknowledges their responsibility, the procedure may be resolved with the imposition of the appropriate sanction.

2. When the sanction is solely pecuniary or when a pecuniary sanction can be imposed alongside a non-pecuniary sanction but the imposition of the latter has been justified as inappropriate, voluntary payment by the presumed responsible party, at any time prior to the resolution, will imply the termination of the procedure, except regarding the restoration of the altered situation or the determination of compensation for damages caused by the commission of the infringement.

3. In both cases, when the sanction is solely pecuniary, the competent authority to resolve the procedure will apply reductions of at least 20% on the amount of the proposed sanction, which may be cumulative. The aforementioned reductions must be specified in the notification of initiation of the procedure, and their effectiveness will be conditioned upon the withdrawal or waiver of any action or appeal in the administrative route against the sanction. The percentage of reduction provided for in this section may be increased by regulation."

III

Voluntary payment

In accordance with the provisions of the aforementioned Article 85 of the LPACAP, the notified resolution proposal allowed for the voluntary payment of the proposed sanction, which would entail a reduction of 20% of its amount. With the application of this reduction, the sanction would be established at 4,927.20 euros, and its payment will imply the termination of the procedure, without prejudice to the imposition of the corresponding measures.

Following the aforementioned resolution proposal, and before a resolution was issued by this authority, the party being claimed, on December 21, 2024, proceeded to make the voluntary payment, availing themselves of the 20% reduction and waiving any action or appeal in the administrative route.

It should be noted that, in accordance with the provisions of the LPACAP, as well as the jurisprudence of the high court in this matter, the exercise of voluntary payment by the presumed responsible party does not exempt the administration from the obligation to resolve and notify all procedures, regardless of their initiation form. Likewise, Article 88 of the aforementioned regulation establishes that the resolution that concludes the procedure will decide all issues raised by the interested parties and any others arising from it.

Therefore, in accordance with the applicable legislation and assessed the criteria for the graduation of the sanctions whose existence has been established, the Presidency of the Spanish Agency for Data Protection RESOLVES:

FIRST: TO DECLARE the commission of the infringements and TO CONFIRM the sanctions

determined in the dispositive part of the resolution proposal transcribed in this resolution.
The sum of the aforementioned amounts yields a total of 6,159.00 euros.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
59/59

After the respondent has proceeded with the prompt payment, although without acknowledgment of responsibility, it is hereby resolved, pursuant to Article 85 of the LPACAP, to reduce the total amount mentioned by 20%, which results in a final amount of 4,927.20 euros.

SECOND: DECLARE the termination of procedure EXP202400072, in accordance with the provisions of Article 85 of the LPACAP.

THIRD: NOTIFY this resolution to BANCO COOPERATIVO ESPAÑOL, S.A.

FOURTH: In accordance with the provisions of Article 85 of the LPACAP, which conditions the reduction for voluntary payment on the withdrawal or renunciation of any action or administrative appeal by the present authority, the express renunciation manifested by the respondent is accepted, consequently precluding the filing of an optional appeal for reconsideration against this resolution, all without prejudice to the possibility of resorting to the contentious-administrative jurisdiction.

Consequently, taking into account the provisions of Article 90 of the LPACAP, since no administrative appeal is possible due to the express renunciation, this resolution will be fully enforceable from the notification thereof.

However, in accordance with the provisions of Article 90.3 a) of the LPACAP, the firm resolution in the administrative process may be provisionally suspended if the interested party expresses their intention to file a contentious-administrative appeal. If this is the case, the interested party must formally communicate this fact by means of a written document addressed to the Spanish Agency for Data Protection, submitting it through the Electronic Registry of the Agency [<https://sedeagpd.gob.es/sede-electronica-web/>], or through any of the other registries provided for in Article 16.4 of the aforementioned Law 39/2015, of October 1. They must also provide the Agency with documentation that proves the effective filing of the contentious-administrative appeal. If the Agency does not become aware of the filing of the contentious-administrative appeal within two months from the day following the notification of this resolution, the provisional suspension would be considered terminated.

In accordance with the provisions of Article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

968-15012025

Olga Pérez Sanjuán

The Deputy Director General of Data Inspection, in accordance with Article 48.2 LOPDGDD, due to vacancy of the Presidency and Deputy Presidency

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es